

Relatório Técnico — Tech Challenge Fase 2

Sistema de Gestão de Restaurantes

Aluno:

- Felipe Dias Mac Dowell

Curso: Pós-Tech — Arquitetura e Desenvolvimento Java **Stack:** Java 21 · Spring Boot 3.5.x · Spring Data JPA · PostgreSQL · Docker **Arquitetura:** Clean Architecture **Versão do relatório:** 1.0

Documento vivo, organizado pelas etapas de desenvolvimento. Cada etapa do Sumário de Progresso abaixo corresponde a uma seção homônima neste relatório.

Esta é a **primeira versão** do relatório da Fase 2. Ela define a arquitetura, o modelo de domínio e as decisões técnicas de um **projeto novo**, construído desde o início sobre a **Clean Architecture** de Robert C. Martin. As seções descrevem o desenho acordado pela equipe; à medida que cada etapa for concluída, o texto correspondente passa a refletir o código entregue.

Sumário de Progresso

#	Etapas	Status
1	Setup do Projeto e Estrutura de Pacotes	✓
2	Camada de Entidades (domínio)	✓
3	Camada de Casos de Uso e Gateways	✓
4	Adaptadores de Interface (Controllers, Gateways, Presenters)	✓
5	Persistência com JPA (infraestrutura)	✓
6	Migrations e Seeds (Flyway)	✓
7	API REST, Segurança e JWT (infraestrutura)	✓
8	Tratamento de Erros (ProblemDetail)	✓
9	Documentação Swagger	✓
10	Execução com Docker Compose	✓
11	Testes — unitários (100% cobertura) e de integração	✓
12	Entregáveis (Postman, README)	✓
13	Infraestrutura em módulos substituíveis	✓

Progresso: 13 de 13 etapas concluídas. **Legenda:** ✓ concluída · 🔄 em andamento · ⌚ pendente.

Mapa dos Entregáveis Obrigatórios

Entregável obrigatório	Onde encontrar
Descrição detalhada da arquitetura	Visão Geral da Arquitetura
Modelagem das entidades e relacionamentos	Etapas 2 e 5
Estrutura do banco de dados (tabelas)	Etapas 5 e 6
Descrição dos endpoints (com exemplos)	Etapas 7
Documentação Swagger	Etapas 9
Coleção Postman	Etapas 12
Passo a passo com Docker Compose	Etapas 10

Visão Geral da Arquitetura

Padrão arquitetural adotado

O projeto adota a **Clean Architecture**, conforme descrita por Robert C. Martin em *Clean Architecture: A Craftsman's Guide to Software Structure and Design* (2017). A ideia central é organizar o sistema em **camadas concêntricas**, em que as camadas internas contêm as regras de negócio e as externas contêm os detalhes técnicos — interface HTTP, banco de dados, frameworks — e garantir que **as dependências apontem sempre para dentro**.

A escolha se justifica por três razões:

1. **Independência de framework.** As regras de negócio e a camada que as adapta não importam nada do Spring, do JPA ou do Hibernate. O núcleo compila e é testado sem framework no classpath; o Spring existe apenas na camada mais externa.
2. **Regras de negócio no domínio.** As entidades são responsáveis pela própria consistência: é a entidade que recusa um e-mail inválido, um nome em branco ou um usuário sem papel — não um objeto de transporte da API nem uma anotação de validação.
3. **Banco de dados como detalhe.** A persistência é uma implementação atrás de uma interface definida pelo núcleo. O JPA é usado com todas as suas facilidades — mapeamento, cascade, auditoria — mas confinado à infraestrutura, com entidades JPA separadas das entidades de domínio.

As quatro camadas

Camada	Pacote	Responsabilidade
Entidades (Entities)	<code>domain/entity</code> , <code>domain/vo</code> , <code>domain/exception</code>	Objetos de negócio com seus invariantes. Criados por fábrica estática <code>create(...)</code> que valida os dados. VOs de valor (<code>Email</code> , <code>ZipCode</code>). Exceções de domínio. Nenhuma dependência além do JDK.
Casos de Uso (Use Cases)	<code>application/usecase</code> , <code>application/gateway</code> , <code>application/dto</code>	Uma classe por ação que o sistema oferece, com <code>create(gateways...)</code> e <code>run(dto)</code> . Orquestram as entidades e requisitam dados pelas interfaces de gateway , declaradas aqui porque é o caso de uso quem define o que precisa.
Adaptadores de Interface	<code>adapter/controller</code> , <code>adapter/gateway</code> , <code>adapter/presenter</code>	Controllers coordenam: instanciam o gateway com a origem de dados recebida, instanciam o caso de uso, entregam o resultado ao presenter. Gateways implementam as interfaces do núcleo e traduzem entidade ↔ dados externos, dependendo apenas de uma interface de origem de dados. Presenters preparam a saída para o cliente.
Frameworks & Drivers	<code>infrastructure/main</code> , <code>infrastructure/web</code> , <code>infrastructure/persistence/jpa</code> , <code>infrastructure/token/jwt</code> , <code>infrastructure/crypto</code> , <code>infrastructure/mail/smtp</code>	Os detalhes, cada um como módulo substituível (Etapa 13): <code>@RestController</code> , DTOs HTTP, HATEOAS, handler de erros e Spring Security; entidades JPA, <code>JpaRepository</code> e a implementação da origem de dados; JWT; BCrypt; SMTP; e a composição que liga tudo. Só aqui existe Spring.

A regra de dependência

O código só pode apontar para dentro. Camadas internas não conhecem as externas; as externas dependem de abstrações definidas nas internas (inversão de dependência). Na prática:

- `domain` não importa nada do projeto nem de bibliotecas;
- `application` importa apenas `domain`;
- `adapter` importa `application` e `domain`;
- `infrastructure` importa qualquer camada — é a única que conhece Spring, JPA e Hibernate.

Essa regra não é convenção: é verificada em build por testes de arquitetura (Etapa 11).

Fluxo de uma requisição



Em caso de erro em qualquer ponto, a exceção de domínio sobe até o handler global da infraestrutura e é convertida em uma resposta padronizada `ProblemDetail` (Etapa 8).

Etapa 1 — Setup do Projeto e Estrutura de Pacotes

Stack e dependências

Tecnologia	Versão	Uso	Camada
Java	21 (LTS)	Linguagem	todas
Spring Boot	3.5.x	Framework base	infrastructure
Spring Web	(gerenciado)	API REST	infrastructure
Spring Data JPA	(gerenciado)	Persistência (Hibernate)	infrastructure
Spring Validation	(gerenciado)	Validação sintática dos DTOs HTTP	infrastructure
Spring Security	(gerenciado)	Autenticação JWT	infrastructure
Spring Mail	(gerenciado)	E-mail de recuperação de senha	infrastructure
Spring HATEOAS	(gerenciado)	Links de navegação nas respostas REST	infrastructure
Spring Boot Actuator	(gerenciado)	Observabilidade (health, info, metrics)	infrastructure
PostgreSQL	16	Banco relacional	infrastructure
Flyway	(gerenciado)	Migração e versionamento de schema	infrastructure
springdoc-openapi	2.8.x	Documentação Swagger	infrastructure
jjwt	0.12.x	Geração/validação de JWT	infrastructure
JUnit 5 + Mockito	(gerenciado)	Testes unitários	testes
Testcontainers	1.20.x	Testes de integração da persistência com PostgreSQL real	testes
ArchUnit	1.4.x	Testes automatizados da regra de dependência	testes
JaCoCo	0.8.x	Cobertura de testes unitários — build falha abaixo de 100%	testes
Maven Surefire / Failsafe	(gerenciado)	Separação entre testes unitários (test) e de integração (integration-test)	testes

A coluna "Camada" registra o compromisso central do projeto: **toda biblioteca de framework é dependência exclusiva de infrastructure**. `domain`, `application` e `adapter` compilam apenas com o JDK. Não há Lombok nem geradores de código no núcleo — construtores, fábricas e acessores são escritos à mão, o que mantém as regras de negócio legíveis sem processador de anotações.

Estrutura de pacotes

Raiz: `com.postech.restaurantes`

```

src/main/java/com/postech/restaurantes/
├─ RestaurantesApplication.java
|
├─ domain/                                # ENTIDADES – zero dependências
|   ├─ entity/
|   |   ├─ user/                          # User (raiz), Role, RoleName, PasswordResetToken
|   |   └─ address/                      # Address (compartilhado por usuário e, adiante, restaurante)
|   └─ vo/                               # Email, ZipCode
|       └─ exception/                   # DuplicateResourceException, ResourceNotFoundException, ...
|
├─ application/                          # CASOS DE USO – depende só de domain
|   ├─ usecase/
|   |   ├─ user/                        # RegisterUserUseCase, UpdateUserUseCase, SearchUsersUseCase, ...
|   |   └─ auth/                       # AuthenticateUseCase, ForgotPasswordUseCase, ResetPasswordUseCase
|   └─ gateway/                        # IUserGateway, IRoleGateway, IPasswordEncoder, IEmailGateway, ...
|       └─ dto/
|           ├─ common/                 # PageRequest, PageResult, SortDirection, AddressDTO
|           ├─ user/                   # NewUserDTO, UpdateUserDTO, ChangePasswordDTO
|           └─ auth/                   # CredentialsDTO, ResetPasswordDTO, IssuedToken
|
├─ adapter/                              # ADAPTADORES DE INTERFACE – depende de application e domain
|   ├─ controller/                    # UserController, AuthController (orquestração)
|   ├─ gateway/                      # UserGateway, RoleGateway, PasswordResetTokenGateway (implementam I*Gateway)
|   ├─ datasource/                   # IUserDataSource, IRoleDataSource, IPasswordResetTokenDataSource
|   |   └─ data/                     # UserData, RoleData, AddressData, PasswordResetTokenData (records)
|   └─ presenter/                   # UserPresenter, AuthPresenter
|       └─ view/                     # UserView, RoleView, AddressView, AuthView (records de saída)
|
└─ infrastructure/                    # FRAMEWORKS & DRIVERS – módulos substituíveis (Etapa 13)
    ├─ main/                         # CompositionConfig (raiz de composição), PasswordResetProperties
    ├─ web/                          # entrega HTTP (Spring MVC)
    |   ├─ api/user/, api/auth/      # @RestController, Request/Response, UserModelAssembler
    |   ├─ error/                   # GlobalExceptionHandler, ProblemDetailFactory, ProblemType
    |   ├─ doc/                     # OpenApiConfig, ErrorResponse, customizers do springdoc
    |   ├─ validation/              # @ValidPassword
    |   └─ security/                # SecurityConfig, BearerTokenAuthenticationFilter, IAccessTokenReader, Authent
    ├─ persistence/jpa/              # PersistenceConfig, TransactionalUnitOfWork
    |   ├─ audit/                   # AuditableJpaEntity, AuthenticatedAuditorAware, ClockDateTimeProvider
    |   └─ user/                    # *JpaEntity (inclui AddressJpaEntity), SpringData*Repository, *DataSourceJpa
    ├─ token/jwt/                   # JwtTokenIssuer (ITokenIssuer + IAccessTokenReader), JwtProperties, JwtConfig
    ├─ crypto/                      # BCryptPasswordAdapter, SecureRandomTokenGenerator
    └─ mail/smtp/                   # SmtplibMailGateway, MailProperties, MailConfig

```

A infraestrutura chegou à forma acima na **Etapa 13**. As subseções "O que foi entregue" das etapas anteriores registram os nomes e pacotes **da época**; a Etapa 13 traz a correspondência.

Cada pacote nasce com um `package-info.java` que documenta sua regra de dependência — o que faz a estrutura compilar vazia e deixa a intenção de cada camada registrada no código, não só neste relatório.

Dentro de cada camada, entidades, casos de uso e DTOs são agrupados **por agregado ou feature** (`user` , `auth` , `address` ; depois `restaurant` , `menu`). É a *screaming architecture* de Martin: a estrutura deve revelar o domínio, não apenas o padrão arquitetural. As regras de ArchUnit usam padrões `..usecase..` / `..gateway..` , então continuam válidas para qualquer subpacote.

O que foi entregue nesta etapa

Projeto em `fase-02/restaurantes/` :

Artefato	Conteúdo
<code>pom.xml</code>	Dependências da tabela acima; Surefire executando os unitários (exclui <code>*IT</code>) e Failsafe executando os <code>*IT</code> na fase <code>integration-test</code> ; JaCoCo com <code>prepare-agent</code> , relatório na fase <code>test</code> e <code>check</code> na fase <code>verify</code> exigindo 100% de linhas e ramos (exclusões: <code>RestaurantesApplication</code> e <code>infrastructure/config/*Config</code>).
<code>src/main/java</code>	<code>RestaurantesApplication</code> e os 19 pacotes da estrutura, cada um com <code>package-info.java</code> .
<code>src/test/java</code>	<code>ArchitectureTest</code> (ArchUnit) com 8 regras , ativas desde o primeiro build graças a <code>allowEmptyShould(true)</code> : arquitetura em anéis (<code>onionArchitecture</code>), <code>domain</code> sem dependências do projeto, <code>application</code> só de <code>domain</code> , <code>adapter</code> nunca de <code>infrastructure</code> , nenhum framework fora de <code>infrastructure</code> , sufixo <code>UseCase</code> , prefixo <code>I</code> em <code>application.gateway</code> e <code>adapter.datasource</code> .
<code>application.yml</code>	Datasource PostgreSQL por variáveis de ambiente; JPA com <code>ddl-auto: validate</code> e <code>open-in-view: false</code> ; Flyway; JWT; mail; springdoc; Actuator com exposição controlada.
<code>Dockerfile</code> , <code>docker-compose.yml</code> , <code>.env.example</code> , <code>.dockerignore</code> , <code>.gitignore</code>	Build multi-stage (Maven → JRE 21 Alpine), serviço <code>db</code> (postgres:16-alpine com healthcheck) e <code>app</code> , variáveis documentadas.
<code>README.md</code> , <code>CHANGELOG.md</code>	Instruções de execução e teste; histórico por etapa.

Verificação. `mvn verify` com JDK 21: compilação limpa, 8 regras de ArchUnit verdes, Failsafe sem ITs ainda, JaCoCo `check` aprovado — **BUILD SUCCESS**. A regra de dependência está, portanto, protegendo o projeto antes de existir a primeira classe de negócio. A primeira execução da regra revelou um detalhe útil: o ArchUnit enxerga os `package-info` como classes, então as regras de nomenclatura os excluem explicitamente.

Etapa 2 — Camada de Entidades (domínio)

Princípio

Cada entidade é responsável pela própria consistência. Não existe, em nenhum ponto do sistema, uma instância de `User` com e-mail inválido ou sem papel — porque a única forma de obter uma é pela fábrica `create(...)` , e ela recusa dados inválidos lançando `InvariantViolationException` — uma `IllegalArgumentException` cuja mensagem é escrita para o usuário e, por isso, pode chegar à resposta HTTP (Etapa 8). Os setters aplicam a mesma validação, de modo que a entidade não pode ser corrompida depois de criada.

Entidades

Entidade	Invariantes garantidos pela própria entidade
User	nome não vazio; e-mail válido e normalizado (<code>Email</code>); login não vazio; hash de senha presente; ao menos um papel ; endereços válidos
Role	nome pertence ao conjunto <code>ROLE_OWNER</code> , <code>ROLE_CUSTOMER</code> , <code>ROLE_ADMIN</code>
Address	rua, cidade e UF obrigatórios; UF com 2 letras; CEP válido e normalizado (<code>ZipCode</code>)
PasswordResetToken	hash do token presente; expiração no futuro na criação; <code>markUsed()</code> só pode ser chamado uma vez

`User` é a **raiz do agregado**: carrega `Set<Role>` e `List<Address>` , e é através dele que endereços são substituídos (`replaceAddresses`) e papéis atribuídos (`replaceRoles`).

VOs de valor

VO	Invariante
Email	formato válido; normalizado para minúsculas
ZipCode	8 dígitos; formatação <code>00000-000</code> sob demanda

A normalização do e-mail para minúsculas dentro de `Email.of(...)` é o que torna a regra de e-mail único correta por construção: `Joao@x.com` e `joao@x.com` produzem o mesmo valor antes de qualquer consulta.

Exemplo

```
// domain/entity/User.java – sem Spring, sem JPA, sem Lombok (trecho)
public final class User {
    private final UUID id;
    private String name;
    private Email email;
    private String login;
    private String passwordHash;
    private final Set<Role> roles = new LinkedHashSet<>();
    private final List<Address> addresses = new ArrayList<>();
    private final LocalDateTime createdAt;
    private final LocalDateTime lastUpdatedAt;

    private User(UUID id, LocalDateTime createdAt, LocalDateTime lastUpdatedAt) { ... }

    /** Usuário novo, ainda sem id nem auditoria. */
    public static User create(String name, String email, String login, String passwordHash,
                             Set<Role> roles, List<Address> addresses) {
        return fill(new User(null, null, null), name, email, login, passwordHash, roles, addresses);
    }

    /** Usuário reconstruído a partir da origem de dados, com id e auditoria conhecidos. */
    public static User restore(UUID id, String name, String email, String login, String passwordHash,
                               Set<Role> roles, List<Address> addresses,
                               LocalDateTime createdAt, LocalDateTime lastUpdatedAt) {
        User user = new User(Guard.requireNonNull(id, "Id do usuário inválido"), createdAt, lastUpdatedAt);
        return fill(user, name, email, login, passwordHash, roles, addresses);
    }

    private static User fill(User user, String name, String email, String login, String passwordHash,
                              Set<Role> roles, List<Address> addresses) {
        user.setName(name);
        user.setEmail(Email.of(email)); // valida formato e normaliza para minúsculas
        user.setLogin(login);
        user.changePasswordHash(passwordHash);
        user.replaceRoles(roles); // exige ao menos um papel
        user.replaceAddresses(addresses);
        return user;
    }

    public void setName(String name) {
        this.name = Guard.requireNotBlank(name, "Nome inválido");
    }

    public void replaceRoles(Set<Role> newRoles) {
        Guard.require(newRoles != null && !newRoles.isEmpty(), "Usuário deve ter ao menos um papel");
        Guard.require(newRoles.stream().noneMatch(Objects::isNull), "Papel inválido");
    }
}
```

```
        roles.clear();
        roles.addAll(newRoles);
    }
    // demais setters validam do mesmo modo; getters devolvem visões imutáveis das coleções
}
```

`create` é usado para entidades novas (sem id); `restore` reconstrói uma entidade a partir da origem de dados, com id conhecido. Ambos passam pela mesma validação.

Exceções de domínio

Exceção	Situação
<code>ResourceNotFoundException</code>	usuário ou papel inexistente
<code>DuplicateResourceException</code>	e-mail ou login já cadastrado
<code>InvalidPasswordException</code>	senha atual incorreta ou confirmação divergente
<code>ForbiddenOperationException</code>	autocadastro solicitando papel privilegiado (<code>ROLE_ADMIN</code>)
<code>InvalidOrExpiredTokenException</code>	token de redefinição inexistente, expirado ou já usado
<code>InvalidCredentialsException</code>	login ou senha incorretos

São exceções não verificadas, sem nenhuma anotação: quem as traduz para HTTP é a infraestrutura (Etapa 8). Todas estendem a base abstrata `DomainException`, o que permite ao handler tratá-las por família quando conveniente.

O que foi entregue nesta etapa

Pacote `domain` completo, com **15 classes e zero imports** fora do JDK:

Tipo	Decisões de implementação
Guard	Utilitário de invariantes (<code>requireNonNull</code> , <code>requireNotBlank</code> , <code>require</code> , <code>trimOrNull</code>). Concentra as verificações para que as entidades leiam como regras, não como <code>if</code> s. Toda violação é <code>IllegalArgumentException</code> .
Email , ZipCode	<code>records</code> com construtor compacto: validam e normalizam na construção (minúsculas / só dígitos), então a igualdade por valor do record já embute a normalização — <code>Email.of("Joao@x.com").equals(Email.of("joao@x.com"))</code> é verdadeiro.
RoleName	Enum com <code>from(String)</code> tolerante a caixa e <code>isPrivileged()</code> (só <code>ROLE_ADMIN</code>).
Role	Identidade de negócio pelo nome: <code>equals</code> / <code>hashCode</code> ignoram o id, permitindo comparar um papel recém-criado com um restaurado do banco dentro de um <code>Set</code> .
Address	Rua, cidade, UF (2 letras, normalizada para maiúsculas) e CEP obrigatórios; número, complemento e bairro opcionais com "em branco vira ausente".
User	Raiz do agregado. <code>create</code> (sem id/auditoria) e <code>restore</code> (com id, <code>createdAt</code> , <code>lastUpdatedAt</code>) passam pelo mesmo <code>fill</code> , então não há caminho que produza instância inválida. <code>replaceRoles</code> / <code>replaceAddresses</code> substituem as coleções por completo; <code>getRoles</code> / <code>getAddresses</code> devolvem visões imutáveis. O domínio recebe o hash da senha — nunca a senha nem o algoritmo.
PasswordResetToken	Guarda só o hash do token. O instante de referência é parâmetro (<code>create(..., now)</code> , <code>isExpired(now)</code> , <code>isUsable(now)</code>), mantendo a entidade sem relógio e os testes determinísticos. <code>markUsed()</code> é de uso único e a segunda chamada é <code>IllegalStateException</code> — violação de estado, não de argumento.
DomainException + 6 subclasses	<code>RuntimeException</code> com mensagem; sem anotação e sem código HTTP.

Testes unitários — 111 casos em 8 classes (`GuardTest` , `EmailTest` , `ZipCodeTest` , `RoleNameTest` , `RoleTest` , `AddressTest` , `UserTest` , `PasswordResetTokenTest` , `DomainExceptionsTest`), sem mocks e sem Spring. Cada invariante tem um teste que prova a recusa (`assertThrows`) e um que prova a aceitação; os casos de "em branco" usam `@ParameterizedTest` com `@NullAndEmptySource` . Cobertura medida pelo JaCoCo no pacote `domain` : **170/170 linhas, 44/44 ramos, 83/83 métodos** — 100%.

Verificação. `mvn verify` : 119 testes (111 unitários + 8 regras de ArchUnit), **BUILD SUCCESS**, regra de cobertura aprovada. Os testes pegaram um defeito real antes do primeiro uso: a verificação "nenhum elemento nulo" usava `contains(null)` , que em coleções imutáveis (`Set.of` , `List.of`) lança `NullPointerException` em vez de responder `false` . Foi trocada por `stream().noneMatch(Objects::isNull)` .

Etapa 3 — Camada de Casos de Uso e Gateways

Casos de uso

Cada ação que o sistema oferece é uma classe própria, instanciada por `create(...)` com as interfaces de que depende e executada por `run(...)` . O caso de uso **orquestra**: consulta gateways, cria ou altera entidades, aplica as regras de aplicação e devolve a entidade resultante. Ele não sabe de HTTP, de JSON nem de banco de dados.

Caso de uso	Regras aplicadas
RegisterUserUseCase	rejeita <code>ROLE_ADMIN</code> no autocadastro (<code>ForbiddenOperationException</code>); garante unicidade de e-mail e login; aplica hash na senha via <code>IPasswordEncoder</code> ; resolve papéis via <code>IRoleGateway</code> ; cria <code>User</code>
UpdateUserUseCase	atualiza nome, e-mail e login (revalidando unicidade, ignorando o próprio registro) e substitui endereços; não altera senha
ChangePasswordUseCase	confere a senha atual, valida que nova senha e confirmação coincidem, grava o novo hash
DeleteUserUseCase	remove o usuário (endereços, tokens e vínculos de papel caem por cascade)
FindUserByIdUseCase	consulta por id; <code>ResourceNotFoundException</code> se inexistente
SearchUsersUseCase	listagem paginada, com busca parcial por nome sem diferenciar maiúsculas; ordenação por propriedades permitidas
AuthenticateUseCase	busca por login, compara hash via <code>IPasswordEncoder</code> , emite token via <code>ITokenIssuer</code> ; <code>InvalidCredentialsException</code> em falha — com a mesma mensagem e o mesmo custo de tempo para login inexistente e senha incorreta
ForgotPasswordUseCase	se o e-mail existir, gera token de uso único, persiste o hash e envia por <code>IMailGateway</code> ; resposta idêntica exista ou não o e-mail
ResetPasswordUseCase	valida token (existe, não expirou, não usado), confere confirmação, invalida o token e só então grava o novo hash

Regra de negócio × regra de aplicação

A distinção orienta onde cada regra mora:

- **Regra de negócio** (vale em qualquer contexto): e-mail válido, ao menos um papel, CEP com 8 dígitos → **na entidade**.
- **Regra de aplicação** (depende do ponto de entrada): `ROLE_ADMIN` proibido *no autocadastro público*, resposta idêntica no "esqueci minha senha" → **no caso de uso**.

Gateways (interfaces)

Declaradas em `application/gateway` , em termos de domínio — recebem e devolvem entidades e VOs, nunca tipos de framework:

Interface	Operações
IUserGateway	findById, findByLogin, findByEmail, search(name, PageRequest), insert, update, delete
IRoleGateway	findByName(Set<RoleName>)
IPasswordResetTokenGateway	findByTokenHash, insert, update
IPasswordEncoder	encode, matches, simulateMatch (gasta o tempo de uma comparação quando não há hash real — o núcleo não conhece o algoritmo)
ITokenIssuer	issue(User) → IssuedToken(token, expiresAt)
IMailGateway	sendPasswordReset(Email, rawToken)
ISecureTokenGenerator	generate() → token aleatório em claro; hash(rawToken) → hash determinístico para persistir e consultar
IUnitOfWork	execute(Supplier) / execute(Runnable) — executa um bloco de forma atômica; usada pelo controller de adaptação ao invocar um caso de uso

A paginação é expressa por tipos próprios de application/dto (PageRequest , PageResult<T>), não por Pageable / Page do Spring — a tradução acontece na infraestrutura.

ISecureTokenGenerator existe por dois motivos: a escolha de algoritmo (SecureRandom , SHA-256) é detalhe de infraestrutura, e o token gerado precisa ser **determinístico nos testes** dos casos de uso — com um mock, o teste sabe exatamente qual hash deve ter sido persistido e qual valor em claro deve ter ido para o e-mail.

Exemplo

```
// application/usecase/RegisterUserUseCase.java
public final class RegisterUserUseCase {
    private final IUserGateway userGateway;
    private final IRoleGateway roleGateway;
    private final IPasswordEncoder passwordEncoder;

    private RegisterUserUseCase(IUserGateway userGateway, IRoleGateway roleGateway,
                                IPasswordEncoder passwordEncoder) { ... }

    public static RegisterUserUseCase create(IUserGateway userGateway, IRoleGateway roleGateway,
                                              IPasswordEncoder passwordEncoder) {
        return new RegisterUserUseCase(userGateway, roleGateway, passwordEncoder);
    }

    public User run(NewUserDTO dto) {
        Guard.requireNonNull(dto, "Dados de cadastro inválidos");
        Set<RoleName> roleNames = dto.roles();
        Guard.require(roleNames != null && !roleNames.isEmpty(), "Usuário deve ter ao menos um papel");
        if (roleNames.stream().anyMatch(RoleName::isPrivileged)) {
            throw new ForbiddenOperationException("Autocadastro não pode conceder papel de administrador");
        }
        Email email = Email.of(dto.email());
        if (userGateway.findByEmail(email).isPresent()) {
            throw new DuplicateResourceException("E-mail já cadastrado");
        }
        String login = Guard.requireNonBlank(dto.login(), "Login inválido");
        if (userGateway.findByLogin(login).isPresent()) {
            throw new DuplicateResourceException("Login já cadastrado");
        }
        Set<Role> roles = roleGateway.findByName(roleNames);
        if (roles.size() != roleNames.size()) {
            throw new ResourceNotFoundException("Papel inexistente");
        }
        String rawPassword = Guard.requireNonBlank(dto.password(), "Senha inválida");
        User user = User.create(dto.name(), email.value(), login, passwordEncoder.encode(rawPassword),
                                roles, AddressDTO.toEntities(dto.addresses()));
        return userGateway.insert(user);
    }
}
```

A conversão de endereços fica em `AddressDTO.toEntities(...)` — na camada de aplicação, que conhece o domínio — e não em um `Address.fromDTOs(...)`, que faria o domínio conhecer um DTO de fora e violaria a regra de dependência.

O que foi entregue nesta etapa

Pacote `application` completo — **10 DTOs, 7 interfaces de gateway e 9 casos de uso** — importando apenas `domain` e o JDK:

Componente	Decisões de implementação
<code>PageRequest</code> / <code>PageResult<T></code>	Records próprios de paginação: página base 0, tamanho 1–100, ordenação opcional. <code>PageResult.map(...)</code> permite ao presenter converter o conteúdo sem perder os metadados; o conteúdo é copiado e imutável.
<code>AddressDTO</code> , <code>NewUserDTO</code> , <code>UpdateUserDTO</code> , <code>ChangePasswordDTO</code> , <code>CredentialsDTO</code> , <code>ResetPasswordDTO</code> , <code>IssuedToken</code> , <code>SortDirection</code>	Records de transporte. Só <code>IssuedToken</code> válida (token não vazio, expiração presente); os demais são validados por quem os consome.
Casos de uso	Todos <code>final</code> , com construtor privado, <code>create(...)</code> recebendo apenas interfaces e <code>run(...)</code> . Nenhum <code>@Service</code> , nenhum <code>@Transactional</code> : a transação é aberta pela origem de dados, na infraestrutura.
<code>RegisterUserUseCase</code>	Rejeita papel privilegiado antes de qualquer consulta; unicidade de e-mail (já normalizado pelo VO) e de login; confere que todos os papéis pedidos existem (<code>ResourceNotFoundException</code> se algum faltar); a senha só chega ao <code>IPasswordEncoder</code> depois de validada.
<code>UpdateUserUseCase</code>	Unicidade revalidada com <code>Optional.filter(other -> !other.getId().equals(id))</code> — o próprio registro não conta como duplicata. Senha intocada.
<code>ChangePasswordUseCase</code> / <code>ResetPasswordUseCase</code>	Ordem das verificações escolhida para falhar cedo e barato: senha atual (ou token) → nova senha não vazia → confirmação → só então o hash e a gravação.
<code>SearchUsersUseCase</code>	Lista fixa <code>SORTABLE_PROPERTIES</code> ; propriedade fora dela (inclusive <code>password</code>) cai em <code>name ASC</code> em vez de erro, preservando o contrato de <code>200</code> para <code>sort</code> desconhecido.
<code>AuthenticateUseCase</code>	Login inexistente e senha incorreta lançam a mesma <code>InvalidCredentialsException</code> com a mesma mensagem, para não revelar quais logins existem.
<code>ForgotPasswordUseCase</code>	Recebe <code>Duration</code> de validade e <code>Clock</code> na criação (validados). E-mail inexistente retorna em silêncio sem tocar nos gateways de token e e-mail — a resposta é idêntica ao caso de sucesso. Persiste só o hash; o valor em claro vai apenas para <code>IMailGateway</code> .

Testes unitários — 70 casos em 10 classes (`PageRequestTest`, `PageResultTest`, `DtoTest`, `RegisterUserUseCaseTest`, `UpdateUserUseCaseTest`, `ChangePasswordUseCaseTest`, `UserQueryUseCasesTest` com `@Nested` para Find/Delete/Search, `AuthenticateUseCaseTest`, `ForgotPasswordUseCaseTest`, `ResetPasswordUseCaseTest`), com **Mockito** para as interfaces de gateway e `Clock.fixed` para o tempo — sem contexto Spring, sem banco. `ArgumentCaptor` verifica o que foi entregue aos gateways (o hash persistido, o token em claro enviado, a ordenação sanitizada). Uma armadilha do JUnit 5 documentada no código: em classes `@Nested` o inicializador de campo roda **antes** do `@BeforeEach` externo, então o caso de uso é criado em um `@BeforeEach` aninhado.

Revisão de código da etapa. Antes de fechar, o diff passou por uma revisão focada em falhas reais, que apontou cinco problemas — todos corrigidos com teste correspondente:

Achado	Correção
<code>ResetPasswordUseCase</code> gravava a senha antes de marcar o token como usado. Como cada gateway é a própria transação, uma falha entre as duas escritas deixaria a senha trocada e o token reutilizável.	Ordem invertida: o token é invalidado e persistido primeiro; se a gravação da senha falhar, o efeito é "peça um novo token". Teste com <code>InOrder</code> e um teste em que <code>tokenGateway.update</code> lança e a senha permanece intacta.
<code>RegisterUserUseCase</code> : "roles": [null] passava pela checagem nulo/vazio e estourava <code>NullPointerException</code> (500) em <code>RoleName::isPrivileged</code> .	<code>Guard.require(roleNames.stream().noneMatch(Objects::isNull), ...)</code> → 400.
<code>AddressDTO.toEntities</code> : "addresses": [null] produzia NPE (500) no <code>map</code> .	Mesma guarda → <code>IllegalArgumentException("Endereço inválido")</code> → 400.
<code>AuthenticateUseCase</code> : login inexistente retornava sem executar o BCrypt; a diferença de latência (~1 ms × ~100 ms) permitia enumerar logins apesar da mensagem única.	Quando o login não existe, a senha é comparada contra um hash BCrypt fixo (<code>DUMMY_HASH</code>), igualando o custo dos dois caminhos; o resultado dessa comparação é ignorado.
Senha nula chegava ao <code>IPasswordEncoder</code> ; o <code>BCryptPasswordEncoder</code> lança <code>IllegalArgumentException("rawPassword cannot be null")</code> , que viraria 400 com mensagem interna em vez de 401 — e, no login, revelaria que o login existe.	<code>AuthenticateUseCase</code> trata login/senha em branco como <code>InvalidCredentialsException</code> antes de qualquer consulta; <code>ChangePasswordUseCase</code> trata senha atual em branco como <code>InvalidPasswordException</code> .

Revisão de arquitetura da etapa. Em seguida o código foi confrontado com as referências deste relatório (regra de dependência, entidades donas dos invariantes, "frameworks e banco são detalhes", *screaming architecture*). Conformidades verificadas por grep e ArchUnit: zero imports fora do JDK em `domain / application`, nenhum `now()` no domínio, casos de uso sem anotação. Dois ajustes saíram da revisão:

Achado	Correção
A correção do tempo constante no login tinha colocado um hash BCrypt constante dentro do caso de uso — o núcleo passou a conhecer o algoritmo, contrariando a própria documentação de <code>IPasswordEncoder</code> . Trocar o encoder (Argon2, PBKDF2) quebraria o efeito silenciosamente.	<code>IPasswordEncoder.simulateMatch(rawPassword)</code> : a interface promete "gaste o mesmo tempo"; a implementação, na infraestrutura, sabe qual hash fictício usar. O caso de uso volta a não saber nada de BCrypt.
Estrutura "gritava" Clean Architecture, não o domínio: nove casos de uso num só pacote, e o escopo da fase (restaurantes, cardápio) triplicaria isso.	Subpacotes por agregado/feature em cada camada (<code>domain/entity/user</code> , <code>application/usecase/auth</code> , ...), com <code>package-info</code> próprio. Regras de ArchUnit inalteradas.

Dois pontos ficaram registrados como decisões conscientes, sem mudança: a auditoria (`createdAt / lastUpdatedAt`) vive na entidade de domínio apenas para leitura, porque a API a expõe; e a lista `SORTABLE_PROPERTIES` usa os nomes dos atributos do domínio — o data source JPA deve **traduzi-los**, não repassá-los. Um terceiro ponto foi encaminhado para a Etapa 4: casos de uso com mais de uma escrita (`ResetPasswordUseCase`) precisam de uma porta de unidade de trabalho (`IUnitOfWork`) usada pelo controller de adaptação, já que `@Transactional` fica confinado ao data source.

Verificação. `mvn verify` : 196 testes (188 unitários + 8 regras de ArchUnit), **BUILD SUCCESS**. Cobertura acumulada (`domain` + `application`): 100% de linhas, ramos e métodos.

Etapa 4 — Adaptadores de Interface (Controllers, Gateways, Presenters)

Esta camada disciplina a comunicação entre o núcleo e o mundo exterior. Ela **não contém regra de negócio**; contém tradução e orquestração.

Controllers (adapter/controller)

O controller de adaptação é o ponto de entrada do núcleo. Ele recebe uma **origem de dados por interface** (`IUserDataSource`), e com ela:

1. instancia o gateway (`UserGateway.create(dataSource)`);
2. instancia o caso de uso (`RegisterUserUseCase.create(gateway, ...)`);
3. executa `run(dto)`;
4. entrega a entidade ao presenter e devolve o DTO de saída.

É o controller quem "sabe quem sabe": conhece os componentes e a ordem em que se combinam, mas não a lógica de nenhum deles. Como recebe a origem de dados de fora, o mesmo controller funciona com JPA, com um mapa em memória nos testes, ou com qualquer outra implementação.

```
// adapter/controller/UserController.java (trecho)
public final class UserController {
    private final IUserDataSource userDataSource;
    private final IRoleDataSource roleDataSource;
    private final IPasswordEncoder passwordEncoder;
    private final IUnitOfWork unitOfWork;

    public static UserController create(IUserDataSource userDataSource, IRoleDataSource roleDataSource,
                                      IPasswordEncoder passwordEncoder, IUnitOfWork unitOfWork) { ... }

    public UserView register(NewUserDTO dto) {
        var useCase = RegisterUserUseCase.create(userGateway(), RoleGateway.create(roleDataSource), passwordEncoder);
        return UserPresenter.toView(unitOfWork.execute(() -> useCase.run(dto)));
    }

    public void changePassword(UUID id, ChangePasswordDTO dto) {
        var useCase = ChangePasswordUseCase.create(userGateway(), passwordEncoder);
        unitOfWork.execute(() -> useCase.run(id, dto));
    }

    private UserGateway userGateway() {
        return UserGateway.create(userDataSource);
    }
}
```

O `execute` da unidade de trabalho envolve **cada** `run`: é o controller — e não o caso de uso — que demarca a atomicidade, porque o caso de uso não deve saber que existe transação; e é `IUnitOfWork`, e não `@Transactional`, porque o adaptador não pode conhecer o Spring.

Gateways (adapter/gateway)

Implementam as interfaces `I*Gateway` do núcleo. São **tradutores**: recebem uma entidade, convertem para o DTO que a origem de dados entende, chamam a interface `I*DataSource` e reconstroem a entidade (`User.restore(...)`) com o resultado. O gateway não sabe se a origem de dados é um banco relacional, um serviço remoto ou memória — ele depende apenas da interface.

Interfaces de origem de dados (adapter/datasource)

`IUserDataSource` , `IRoleDataSource` e `IPasswordResetTokenDataSource` definem, em termos de DTOs simples (records), as operações que a infraestrutura precisa oferecer. É o contrato que a Etapa 5 implementa com JPA.

Presenters (adapter/presenter)

Preparam a saída. `UserPresenter.toView(user)` produz a `UIView` que o cliente pode consumir — e é o único lugar onde se decide o que **não** sai: a senha (hash) nunca cruza para fora. Os modelos de saída chamam-se *views* (`UIView` , `RoleView` , `AddressView` , `AuthView`) para não se confundirem com os DTOs de **entrada** dos casos de uso. O presenter retira do controller a obrigação de adaptar entidades e garante um formato padrão de retorno, independentemente de quem consome (REST hoje, outro canal amanhã).

Unidade de trabalho (decisão desta etapa)

A revisão de arquitetura da Etapa 3 deixou registrado que casos de uso com mais de uma escrita (`ResetPasswordUseCase`) não eram atômicos, porque `@Transactional` fica confinado ao data source. Pelo princípio orientador, a solução tinha de ser consistente com a arquitetura: a **transação** é detalhe de infraestrutura (Martin), mas a **demarcação** — "estas escritas acontecem juntas ou nenhuma" — é regra de aplicação. Por isso:

- a porta `IUnitOfWork` é declarada em `application/gateway` , ao lado das demais;
- quem a usa é o **controller de adaptação**, envolvendo cada `run` — o caso de uso continua sem saber que transação existe;
- a implementação (Etapa 5) usa o `TransactionTemplate` do Spring, em `infrastructure` .

A ordem "token antes da senha" adotada na Etapa 3 permanece como defesa em profundidade.

O que foi entregue nesta etapa

Pacote `adapter` completo — **3 interfaces de origem de dados + 4 records, 3 gateways, 2 presenters + 4 views, 2 controllers** — importando apenas `application` , `domain` e o JDK:

Componente	Decisão e conceito que a sustenta
adapter/datasource (IUserDataSource , IRoleDataSource , IPasswordResetTokenDataSource)	Contrato em termos de records simples (UserData , RoleData , AddressData , PasswordResetTokenData), sem entidade de domínio nem tipo de framework. É a interface que o gateway consome e a infraestrutura implementa — inversão de dependência (SOLID/DIP): o detalhe depende da abstração.
adapter/gateway (UserGateway , RoleGateway , PasswordResetTokenGateway)	Implementam I*Gateway do núcleo e traduzem entidade ↔ record: toData desmonta o agregado (e-mail já normalizado, CEP sem máscara, papéis pelo nome), toEntity reconstrói com restore(...) , que revalida os invariantes — um registro corrompido no banco não vira entidade inválida em memória. Recebem a origem de dados por create(dataSource) , como o curso prescreve.
adapter/presenter (UserPresenter , AuthPresenter)	Únicos pontos que decidem o que sai. UserView não tem campo para o hash — a omissão é estrutural, não um if . PageResult.map preserva os metadados da página. AuthPresenter acrescenta o esquema Bearer : convenção de apresentação, não do núcleo.
adapter/controller (UserController , AuthController)	O "maestro": recebe origens de dados e serviços técnicos por interface , monta gateway + caso de uso por operação, executa em IUnitOfWork e entrega ao presenter. Nenhuma regra de negócio; todas as dependências validadas na criação.
IUnitOfWork	Porta de unidade de trabalho (ver acima).
ArchUnit	Três regras novas: records de adapter.datasource.data terminam em Data ; views terminam em View ; toda classe em adapter.gateway implementa uma interface de application.gateway — um gateway sem porta no núcleo não compila o build. A regra de prefixo I passou a mirar exatamente o pacote adapter.datasource (os records ficam em data) .

Testes unitários — 45 casos em 5 classes (UserGatewayTest , RoleAndTokenGatewaysTest , PresentersTest , UserControllerTest , AuthControllerTest). Gateways e presenters com mocks de I*DataSource ; os controllers são testados "de ponta a ponta dentro do núcleo" — origens de dados mockadas, mas casos de uso, gateways e presenters **reais** — provando a orquestração sem repetir os testes de regra. Uma CountingUnitOfWork de teste confirma que cada operação passa exatamente uma vez pela unidade de trabalho.

Verificação. mvn verify : 242 testes (231 unitários + 11 regras de ArchUnit), **BUILD SUCCESS**. Cobertura acumulada (domain + application + adapter): **487/487 linhas, 126/126 ramos, 211/211 métodos, 50 classes** — 100%.

Etapa 5 — Persistência com JPA (infraestrutura)

Entidades JPA separadas das entidades de domínio

Anotar as entidades de domínio com @Entity acoplaria o núcleo ao Hibernate e faria as regras de negócio dependerem do ciclo de vida do ORM. Por isso a persistência tem **as próprias classes**: UserJpaEntity , RoleJpaEntity , PasswordResetTokenJpaEntity em infrastructure/persistence/user e AddressJpaEntity em infrastructure/persistence/address — os subpacotes espelham domain/entity/user e domain/entity/address , de modo que cada agregado novo (restaurante, cardápio) ganhe o seu também aqui. Elas não têm nenhuma

invariante: são mapeamento e nada mais. A tradução entre elas e os records da origem de dados é responsabilidade dos `*DataSourceJpa`.

Decisões de mapeamento

Decisão	Detalhe
Relacionamentos declarativos	<code>@OneToMany(mappedBy = "user", cascade = ALL, orphanRemoval = true)</code> para endereços; <code>@ManyToMany + @JoinTable(name = "user_roles")</code> para papéis. <code>replaceAddresses</code> troca a coleção inteira e o <code>orphanRemoval</code> apaga os que saíram — é a tradução literal de <code>User.replaceAddresses</code> , que também substitui a lista como um todo. Consequência assumida: endereço trocado recebe um id novo.
Papéis são catálogo	O vínculo N:M aponta para linhas que já existem em <code>roles</code> (resolvidas por id antes de gravar); a origem de dados nunca cria um papel.
Identificadores UUID	Chaves primárias <code>UUID</code> . A entidade JPA declara <code>@Id @GeneratedValue(strategy = GenerationType.UUID)</code> — nas linhas criadas pela aplicação quem emite o valor é o Hibernate, antes do <code>INSERT</code> ; o <code>DEFAULT gen_random_uuid()</code> da migration atende seeds e inserções manuais. Ids aleatórios evitam enumeração de recursos pela API.
Auditoria é de quem grava	<code>AuditableJpaEntity (@MappedSuperclass + @EntityListeners(AuditingEntityListener.class))</code> concentra as quatro colunas, todas preenchidas pelo listener. Auditoria é metadado de gravação , não regra: nenhuma invariante depende de quando ou por quem uma linha foi escrita, e <code>User.create</code> sequer recebe um instante — quem recebe é <code>PasswordResetToken</code> , porque ali o tempo é regra (o token vence). O instante vem do <code>ClockDateTimeProvider</code> , ligado ao mesmo <code>Clock</code> injetado nos casos de uso, para que a aplicação tenha um relógio só; o autor vem do <code>AuthenticatedAuditorAware</code> — login autenticado, ou <code>"system"</code> para requisição anônima, migration e seed. A origem de dados não escreve essas colunas, e há teste guardando isso.
Schema é do Flyway	<code>spring.jpa.hibernate.ddl-auto: validate</code> — o Hibernate confere o mapeamento contra o schema migrado e nunca o altera.
Sem sessão aberta na view	<code>spring.jpa.open-in-view: false</code> . Todo mapeamento JPA → record acontece dentro da transação da origem de dados.
N+1 e paginação, sem escolher entre os dois	Paginar e fazer <code>join fetch</code> na mesma consulta faz o Hibernate trazer todas as linhas e recortar a página em memória. Por isso a busca usa duas consultas : a primeira pagina só os ids no banco; a segunda carrega os usuários daquela página com <code>@EntityGraph(attributePaths = {"roles", "addresses"})</code> , em um único <code>select</code> . <code>findById</code> , <code>findByLogin</code> e <code>findByEmail</code> usam o mesmo grafo.
Senha fora da resposta, por construção	A leitura traz o registro inteiro, hash inclusive: o gateway reconstrói o agregado com <code>User.restore(...)</code> , e hash de senha é invariante — uma projeção sem ele exigiria afrouxar a entidade para acomodar uma otimização de consulta, que é exatamente o detalhe mandando na regra. Quem decide o que sai é o presenter, e <code>UIView</code> não tem campo de senha: a garantia é estrutural, não depende de lembrar de projetar.
Ordenação é traduzida, não repassada	A origem de dados mantém um mapa <code>propriedade do núcleo → atributo JPA</code> e monta o <code>Sort</code> a partir dele. Propriedade fora do mapa — <code>password</code> inclusive — cai em <code>name</code> : o caso de uso já filtra, e a origem de dados filtra de novo, porque é ela quem emite o <code>ORDER BY</code> .
Transação	<code>@Transactional</code> fica nos <code>*DataSourceJpa</code> e em <code>TransactionalUnitOfWork</code> — os únicos componentes que conhecem a unidade de trabalho do Hibernate. Nenhum caso de uso é anotado.

Modelo relacional

Tabela	Tipo	Responsabilidade
users	Entidade forte	Identidade e credenciais do usuário
roles	Entidade forte (lookup)	Papéis de autorização
user_roles	Tabela associativa	Resolve o N:M entre usuários e papéis
addresses	Entidade	Endereços do usuário (1:N)
password_reset_tokens	Entidade	Tokens de uso único para redefinição de senha (1:N com users)

Esquema normalizado até a 3ª Forma Normal / BCNF: papéis e endereços em tabelas próprias (1FN), sem dependências parciais na única chave composta (user_roles , 2FN), sem dependências transitivas em users (3FN), e todo determinante (email , login) é chave candidata (BCNF).

```

erDiagram
    USERS ||--o{ ADDRESSES : possui
    USERS ||--o{ USER_ROLES : tem
    USERS ||--o{ PASSWORD_RESET_TOKENS : solicita
    ROLES ||--o{ USER_ROLES : participa

    USERS {
        uuid id PK
        varchar name
        varchar email UK
        varchar login UK
        varchar password
        timestamp created_at
        timestamp last_updated_at
        varchar created_by
        varchar last_updated_by
    }
    ROLES {
        uuid id PK
        varchar name UK
    }
    USER_ROLES {
        uuid user_id PK_FK
        uuid role_id PK_FK
    }
    ADDRESSES {
        uuid id PK
        uuid user_id FK
        varchar street
        varchar number
        varchar complement
        varchar neighborhood
        varchar city
        varchar state
        varchar zip_code
    }
    PASSWORD_RESET_TOKENS {
        uuid id PK
        uuid user_id FK
        varchar token_hash UK
        timestamp expires_at
        boolean used
    }

```

Todas as FKs usam `ON DELETE CASCADE` : remover um usuário remove endereços, tokens e vínculos de papel sem deixar órfãos — no banco, independentemente do cascade do ORM.

Unidade de trabalho: a implementação da porta da Etapa 4

`TransactionalUnitOfWork` implementa `IUnitOfWork` com o `TransactionTemplate` do Spring. A divisão fecha o desenho começado na etapa anterior: a **demarcação** ("estas escritas acontecem juntas ou nenhuma") é regra de aplicação e vive no controlador de adaptação; o **mecanismo** — transação JDBC, propagação, rollback — é detalhe e vive aqui. É por isso que nenhum caso de uso leva `@Transactional`: a anotação arrastaria o Spring para dentro do núcleo, e o núcleo deixaria de compilar sem o framework.

O que foi entregue nesta etapa

Pacote `infrastructure/persistence` completo — **1 superclasse de auditoria + 4 entidades JPA, 3 repositórios Spring Data, 3 origens de dados, a unidade de trabalho e o `AuditorAware`** — e, com ele, a primeira implementação concreta das interfaces que o adaptador declarou:

Componente	Decisão e conceito que a sustenta
<code>UserJpaEntity</code> , <code>RoleJpaEntity</code> , <code>AddressJpaEntity</code> , <code>PasswordResetTokenJpaEntity</code>	Classes separadas das entidades de domínio, com todas as anotações do ORM e nenhuma regra. O banco é detalhe (Martin): trocar o Hibernate por outra coisa reescreve este pacote e não toca em nenhuma camada de dentro. O token referencia o dono por identidade (<code>user_id</code>), como o domínio o modela, em vez de inventar uma associação navegável que ninguém percorre.
<code>SpringData*Repository</code>	Detalhe de acesso, invisível para o núcleo. A busca paginada é deliberadamente dividida em duas consultas para não pagar paginação em memória (ver acima).
<code>UserDataSourceJpa</code> , <code>RoleDataSourceJpa</code> , <code>PasswordResetTokenDataSourceJpa</code>	Implementam as interfaces de <code>adapter/datasource</code> — inversão de dependência na prática: a seta de código aponta para dentro, contra a seta do fluxo de controle. São o único lugar que sabe que existe um banco relacional, e traduzem record ↔ entidade JPA.
<code>AuditableJpaEntity</code> + <code>AuthenticatedAuditorAware</code>	Auditoria é da camada que grava (ver acima). Consultar o <code>SecurityContextHolder</code> é assunto do contexto de execução, e por isso fica confinado à infraestrutura.
<code>TransactionalUnitOfWork</code>	Implementa <code>IUnitOfWork</code> da Etapa 4 (ver acima).
<code>PersistenceConfig</code>	Só liga a auditoria (<code>@EnableJpaAuditing</code>). Configuração puramente declarativa, sem regra — por isso fica fora da medição de cobertura.
<code>ArchUnit</code>	Três regras novas: classe anotada com <code>@Entity</code> só existe em <code>infrastructure.persistence</code> e termina em <code>JpaEntity</code> ; o sufixo <code>JpaEntity</code> é exclusivo desse pacote; toda implementação de uma interface de <code>adapter.datasource</code> mora ali e termina em <code>DataSourceJpa</code> . Uma anotação de ORM numa entidade de domínio passa a quebrar o build, e não apenas a revisão.

Correção na regra de anéis concêntricos. Com `infrastructure` finalmente povoado, a regra de *onion architecture* acusou 53 violações — ela tratava `adapter` e `infrastructure` como dois adaptadores **irmãos**, e o DSL proíbe que irmãos se conheçam. O desenho correto é o dos anéis: Frameworks & Drivers é o anel externo e depende, para dentro, dos Adaptadores de Interface. A regra passou a declarar `infrastructure` como o único adaptador, com `adapter` no anel interno; a fronteira entre `application` e `adapter` continua garantida pelas regras explícitas, que são mais precisas que o DSL.

Testes unitários — 48 casos em 5 classes (`JpaEntitiesTest`, `UserDataSourceJpaTest`,
`RoleAndTokenDataSourcesJpaTest`, `TransactionalUnitOfWorkTest`, `AuthenticatedAuditorAwareTest`). Repositórios

Spring Data mockados: nenhum teste desta etapa sobe contexto nem banco. Verificam a tradução nos dois sentidos, a tradução da ordenação (inclusive a recusa de `password`), a segunda consulta que não acontece quando a página vem vazia, e que a unidade de trabalho confirma no sucesso e desfaz na falha.

Verificação. `mvn verify` : 290 testes (276 unitários + 14 regras de ArchUnit), **BUILD SUCCESS**. Cobertura acumulada (`domain` + `application` + `adapter` + `infrastructure`): **670/670 linhas, 140/140 ramos, 300/300 métodos, 60 classes** — 100%.

Os **testes de integração** com Testcontainers, que provam este mapeamento contra um PostgreSQL real, são entregues na Etapa 6 — antes das migrations não existe schema para o `ddl-auto: validate` conferir.

Etapa 6 — Migrations e Seeds (Flyway)

O schema é **gerenciado exclusivamente pelo Flyway**, por scripts SQL versionados em `src/main/resources/db/migration`, aplicados na inicialização. O Hibernate apenas valida.

Versão	Arquivo	Conteúdo
V1	<code>V1__create_schema.sql</code>	DDL de <code>users</code> , <code>roles</code> , <code>user_roles</code> , <code>addresses</code> , <code>password_reset_tokens</code> (PKs UUID, colunas de auditoria, FKs com cascade), três índices e o seed do catálogo de papéis
V2	<code>V2__seed_demo_users.sql</code>	Usuários de demonstração: um dono, um cliente e um administrador, com senhas em hash BCrypt, seus vínculos de papel e um endereço

Índices criados em V1: `LOWER(name)` em `users` — a expressão exata que a busca paginada usa — e as duas FKs mais percorridas (`addresses.user_id`, `password_reset_tokens.user_id`).

Login	Senha	Papel
<code>dono.restaurante</code>	<code>dono12345</code>	<code>ROLE_OWNER</code>
<code>cliente.demo</code>	<code>cliente12345</code>	<code>ROLE_CUSTOMER</code>
<code>admin.demo</code>	<code>admin12345</code>	<code>ROLE_ADMIN</code>

Os seeds são apenas para teste; remova-os antes de um ambiente real. O `admin.demo` existe porque `ROLE_ADMIN` não pode ser obtido pelo autocadastro público — a seed é a via legítima de criar um administrador nesta fase.

Regras: migrations aplicadas são imutáveis (o Flyway valida o checksum); toda mudança entra como uma nova migration `V<n>__descricao.sql`; o histórico fica em `flyway_schema_history` e no `CHANGELOG.md` do módulo.

Testes de integração: a outra metade da rede de proteção

Com o schema existindo, entra o segundo nível de teste exigido pelo projeto. Um PostgreSQL `postgres:16-alpine` real sobe pelo Testcontainers, o Flyway aplica as migrations e o contexto Spring inteiro é levantado — **nenhum bean da aplicação é mockado**. O `ddl-auto: validate` faz dessa subida uma verificação em si: qualquer

divergência entre as entidades JPA da Etapa 5 e o DDL desta etapa impede o contexto de iniciar, e toda a suíte falha.

Classe	O que prova
<code>SchemaMigrationIT</code>	As duas migrations aplicadas e registradas no histórico; exatamente as cinco tabelas do modelo; o catálogo com os três papéis de <code>RoleName</code> ; os três usuários de demonstração com o papel previsto, senha em hash e <code>created_by = system</code> ; o endereço da seed lido junto com o agregado; e o <code>ON DELETE CASCADE</code> agindo no banco , por comando SQL direto, sem passar pelo ORM.
<code>UserPersistenceIT</code>	O agregado de usuário de ponta a ponta: gravação e leitura completa, reconstrução da entidade de domínio pelo gateway, consulta por login e por e-mail, autor da auditoria preenchido, substituição de endereços removendo os órfãos, troca de papel sem tocar no catálogo, identidade e data de criação preservadas na atualização, busca paginada sem diferenciar caixa, ordenação chegando ao <code>ORDER BY</code> , propriedade não permitida caindo no padrão, e exclusão em cascata.
<code>PasswordResetTokenPersistenceIT</code>	Gravação e recuperação pelo hash, consumo registrado sem reescrever o resto, unicidade do hash imposta pelo banco e tokens apagados junto com o dono.
<code>TransactionalUnitOfWorkIT</code>	A promessa da unidade de trabalho onde ela é observável: bloco concluído confirma tudo; exceção no meio desfaz inclusive o que já havia sido gravado.

Container único. As classes compartilham um único container, iniciado no carregamento de `IntegrationTestSupport` e removido pelo Ryuk ao fim da execução. Com `@Testcontainers` + `@Container`, a extensão do JUnit encerra o container ao fim da **primeira** classe, enquanto o Spring reaproveita o contexto em cache — as classes seguintes passam a apontar para um banco morto. Os testes são escritos para conviver com o banco compartilhado: cada um cria seus próprios dados com marcas únicas, em vez de depender do estado deixado por outro.

O que foi entregue nesta etapa

Componente	Decisão e conceito que a sustenta
<code>V1__create_schema.sql</code>	O schema é do Flyway, versionado e imutável — o mesmo DDL em toda máquina e em todo ambiente. O Hibernate valida e nunca altera: sem <code>ddl-auto: update</code> , não há schema que dependa de qual código subiu primeiro.
<code>V2__seed_demo_users.sql</code>	Seeds de demonstração com senha em hash : o valor em claro não é persistido nem em migration. <code>admin.demo</code> existe porque <code>ROLE_ADMIN</code> é proibido no autocadastro público — a migration é a via legítima de criar um administrador nesta fase. O vínculo de papel é resolvido pelo nome , não pelo id gerado em V1, então a migration não depende de valores que ela não controla.
<code>IntegrationTestSupport</code> + 4 classes <code>*IT</code>	O segundo nível de teste (ver acima). Rodam só no <code>mvn verify</code> , pelo Failsafe, e exigem Docker; o <code>mvn test</code> continua rápido e sem dependência externa.

Verificação. `mvn verify`: **290 testes unitários** (276 + 14 regras de ArchUnit) e **27 testes de integração** contra PostgreSQL real — **BUILD SUCCESS**. Cobertura pelos testes unitários, sem contar os de integração: **670/670 linhas, 140/140 ramos, 300/300 métodos** — 100%.

Etapa 7 — API REST, Segurança e JWT (infraestrutura)

Endpoints

A camada HTTP (`infrastructure/web`) é fina: valida sintaticamente o DTO de entrada (Bean Validation), converte para o DTO do caso de uso, chama o controller de adaptação e monta a resposta com links HATEOAS.
Versionamento por path (`/api/v1/...`).

Método	Rota	Caso de uso	Sucesso	Autorização
POST	<code>/api/v1/auth/login</code>	<code>AuthenticateUseCase</code>	200 OK + token	Pública
POST	<code>/api/v1/auth/forgot-password</code>	<code>ForgotPasswordUseCase</code>	202 Accepted	Pública
POST	<code>/api/v1/auth/reset-password</code>	<code>ResetPasswordUseCase</code>	204 No Content	Pública
POST	<code>/api/v1/users</code>	<code>RegisterUserUseCase</code>	201 Created + Location	Pública (sem <code>ROLE_ADMIN</code>)
GET	<code>/api/v1/users/{id}</code>	<code>FindUserByIdUseCase</code>	200 OK	Dono ou <code>ROLE_ADMIN</code>
GET	<code>/api/v1/users?name=&page=&size=&sort=</code>	<code>SearchUsersUseCase</code>	200 OK (<code>PagedModel</code>)	<code>ROLE_ADMIN</code>
PUT	<code>/api/v1/users/{id}</code>	<code>UpdateUserUseCase</code>	200 OK	Dono ou <code>ROLE_ADMIN</code>
PATCH	<code>/api/v1/users/{id}/password</code>	<code>ChangePasswordUseCase</code>	204 No Content	Dono ou <code>ROLE_ADMIN</code>
DELETE	<code>/api/v1/users/{id}</code>	<code>DeleteUserUseCase</code>	204 No Content	Dono ou <code>ROLE_ADMIN</code>

Exemplo — cadastro (POST `/api/v1/users`):

```
{
  "name": "João Silva",
  "email": "joao.silva@email.com",
  "login": "joao.silva",
  "password": "senhaSegura123",
  "roles": ["ROLE_CUSTOMER"],
  "addresses": [
    {
      "street": "Rua das Flores",
      "number": "100",
      "complement": "Apto 21",
      "neighborhood": "Centro",
      "city": "São Paulo",
      "state": "SP",
      "zipCode": "01001-000"
    }
  ]
}
```

Resposta 201 Created :

```
{
  "id": "7295577e-afe6-4875-8bbf-d21c21860711",
  "name": "João Silva",
  "email": "joao.silva@email.com",
  "login": "joao.silva",
  "roles": [{ "id": "e19edd91-3b6e-4225-a721-ebfd6a5a576b", "name": "ROLE_CUSTOMER" }],
  "addresses": [{ "id": "a0d64f5e-e511-4b52-871d-582d7a8b18d0", "street": "Rua das Flores",
    "number": "100", "complement": "Apto 21", "neighborhood": "Centro",
    "city": "São Paulo", "state": "SP", "zipCode": "01001000" }],
  "createdAt": "2026-09-15T10:00:00",
  "lastUpdatedAt": "2026-09-15T10:00:00",
  "_links": {
    "self": { "href": "http://localhost:8080/api/v1/users/7295577e-afe6-4875-8bbf-d21c21860711" },
    "users": { "href": "http://localhost:8080/api/v1/users" }
  }
}
```

Exemplo — login (POST /api/v1/auth/login):

```
{ "login": "joao.silva", "password": "senhaSegura123" }
```

Resposta 200 OK :

```
{
  "token": "eyJhbGciOiJIUzI1NiJ9...",
  "type": "Bearer",
  "expiresAt": "2026-09-15T11:00:00"
}
```

A expiração sai como **instante absoluto**, e não como "vale por N milissegundos": um prazo relativo depende de quando a resposta chegou e de o relógio do cliente estar certo. É o presenter quem decide isso — a `AuthView` já carrega `expiresAt`, e a borda HTTP só o repassa.

Segurança

Autenticação **stateless** com JWT assinado em HMAC-SHA256 (`JWT_SECRET` com no mínimo 256 bits, expiração via `JWT_EXPIRATION`). A regra de login vive no `AuthenticateUseCase`; a infraestrutura fornece `IPasswordEncoder` (BCrypt) e `ITokenIssuer` (jwt), e o `JwtAuthenticationFilter` valida o `Bearer` a cada requisição e popula o contexto de segurança.

Autorização por posse. Operações por id aplicam `@PreAuthorize("hasRole('ADMIN') or @userSecurity.isSelf(#id, authentication)")`: um usuário comum só lê, altera ou exclui o próprio cadastro (`403` caso contrário); `ROLE_ADMIN` acessa qualquer um. Isso fecha a falha de referência direta a objeto (IDOR); o UUID aleatório complementa a defesa dificultando a descoberta de ids, mas não a substitui.

Recuperação de senha. Token de 32 bytes de `SecureRandom` em Base64 URL, enviado por e-mail; o banco guarda apenas o hash SHA-256. Uso único e com expiração. A resposta do "esqueci minha senha" é idêntica exista ou não o e-mail, para não revelar quais endereços estão cadastrados. SHA-256 puro, e não BCrypt, porque o segredo já tem 256 bits de entropia: não há dicionário a encarecer, e a consulta pelo hash precisa ser determinística.

401 e 403 querem dizer coisas diferentes. Sem credenciais a resposta é `401` ("identifique-se"); com credenciais válidas mas sem direito ao recurso, `403` ("você não pode"). O padrão do Spring, sem login por formulário nem básico, devolveria `403` nos dois casos — um `HttpStatusEntryPoint` corrige isso.

O que foi entregue nesta etapa

Componente	Decisão e conceito que a sustenta
<code>infrastructure/web/user</code> e <code>.../auth</code>	Dois <code>@RestController</code> finos: validam a sintaxe do corpo, convertem para o DTO do caso de uso, delegam ao controller de adaptação e devolvem a representação. Nenhuma regra de negócio — trocar REST por outro canal não reescreve nada de dentro. Subpacotes por feature, como nas demais camadas.
<code>*Request</code> / <code>*Response</code> separados dos DTOs do núcleo	A segunda fronteira de mapeamento prometida no desenho. Bean Validation (<code>@NotBlank</code> , <code>@Email</code> , <code>@Size</code>) vive só aqui: é validação sintática , e a consistência continua sendo do domínio — "as duas senhas conferem" é regra e ficou no caso de uso, não em uma anotação. Papel desconhecido é convertido por <code>RoleName.from</code> , para que o erro seja a mensagem do domínio e não um erro de formato do Jackson.
<code>UserResponse.from(UserView)</code>	A resposta nasce da view, que não tem campo de senha: não existe caminho de código capaz de serializar o hash.
<code>UserModelAssembler</code>	HATEOAS é característica do canal REST, não do caso de uso — por isso nenhum rastro dele chega à <code>UserView</code> . <code>PagedModel</code> preserva os metadados do <code>PageResult</code> do núcleo e dá os links <code>self</code> / <code>first</code> / <code>last</code> e, quando existem, <code>prev</code> / <code>next</code> , repetindo a busca e a ordenação pedidas: o cliente percorre a listagem seguindo links, sem montar URL. (Os links de navegação faltavam na entrega original e foram acrescentados na Etapa 11, quando a suíte passou a verificá-los.)
<code>BCryptPasswordEncoder</code>	Implementa <code>IPasswordEncoder</code> ; é o único lugar que conhece BCrypt. <code>simulateMatch</code> gasta o tempo de uma comparação real contra um hash descartável, de modo que "login inexistente" não responda mais rápido que "senha errada".
<code>JwtTokenIssuer</code>	Implementa <code>ITokenIssuer</code> e também lê o token: emitir e validar o mesmo formato é uma responsabilidade só. Para o núcleo o token é texto opaco com uma expiração. O instante vem do <code>Clock</code> injetado, o que torna a expiração verificável em teste. Recusa devolve vazio sem dizer o motivo — a explicação só ajudaria quem está sondando.
<code>JwtAuthenticationFilter</code>	Apenas traduz o <code>Bearer</code> em contexto de segurança; nunca decide se a requisição passa. Token inválido segue anônimo, e quem recusa é a configuração — assim a regra de "o que exige autenticação" fica em um lugar só.
<code>UserSecurity</code> + <code>@PreAuthorize</code>	Fecha a referência direta a objeto (IDOR): conhecer o id de outra pessoa não dá acesso a ela. O UUID aleatório dificulta descobrir ids — dificultar não é impedir, e a verificação é o que impede.
<code>SecureRandomTokenGenerator</code> , <code>SmtplibMailGateway</code>	Implementam <code>ISecureTokenGenerator</code> e <code>IMailGateway</code> . O token em claro existe em um lugar só: o corpo do e-mail.
<code>CompositionConfig</code>	A raiz de composição — o único ponto onde o núcleo é amarrado às implementações concretas. Os controllers de adaptação são objetos comuns, criados pelas fábricas estáticas e recebendo tudo por interface: não são componentes do Spring e não sabem que ele existe. É aqui que a inversão de dependência deixa de ser desenho e vira montagem.

Correção na auditoria (Etapa 5). O primeiro `POST /api/v1/users` de verdade falhou com `created_at` nulo, e o defeito era de desenho, não de código: a Etapa 5 dizia que o instante "vem do núcleo", mas `User.create` nunca recebeu instante nenhum — só `restore` os carrega, ao reconstruir o que já estava gravado. Auditoria é metadado de gravação, e passou a ser escrita inteiramente pelo listener, com o instante vindo do mesmo `Clock` da aplicação. A tabela da Etapa 5 foi reescrita, e um teste impede que a origem de dados volte a carimbar essas colunas.

Testes unitários — 57 casos em 7 classes, com o controller de adaptação mockado: provam a delegação, a conversão nas duas bordas, a montagem dos links, a emissão e leitura do token (inclusive expirado, adulterado e com outra assinatura), o filtro, a regra de posse e o e-mail.

Testes de integração — 18 casos em 2 classes, por HTTP de verdade, com a cadeia de filtros inteira: é a única forma de provar que o `@PreAuthorize` está mesmo ligado — um teste de unidade do controller passaria igual com a anotação apagada. `UserApiIT` cobre cadastro público, 401 sem token, 403 no cadastro alheio, acesso do administrador, listagem paginada, atualização, troca de senha e exclusão. `AuthApiIT` cobre o ciclo completo de recuperação: pedir, capturar o token no e-mail (único bean mockado), redefinir, entrar com a senha nova e ver o mesmo token ser recusado na segunda vez.

Revisão de código da etapa. Antes de fechar, o diff passou por uma revisão focada em falhas reais, que apontou seis problemas — dois de segurança. Conferidas as etapas seguintes, nenhuma resolveria cinco deles: a Etapa 8 traduz exceções para `ProblemDetail`, o que melhora o corpo da resposta sem corrigir causa nenhuma. Todos foram corrigidos aqui, com teste correspondente:

Achado	Correção
GET /api/v1/users aberto a qualquer autenticado. Devolvia e-mail, login e endereço residencial de todos os cadastros — entregando de uma vez o que a regra de posse recusava um a um nas operações por id.	<code>@PreAuthorize("hasRole('ADMIN')")</code> . Listar o conjunto de cadastros é operação administrativa; um usuário comum enxerga o próprio cadastro e nada mais — a mesma regra, aplicada com consistência. Teste de integração: 403 para usuário comum, 200 para administrador.
Segredo do JWT padrão, versionado e aceito na subida. A validação conferia só o tamanho, e o valor de exemplo tinha 60 bytes. Quem subisse sem <code>JWT_SECRET</code> ficava com um segredo público, e quem conhece o segredo assina um token com <code>ROLE_ADMIN</code> .	<code>application.yml</code> sem valor padrão; <code>JwtProperties</code> recusa também os valores de exemplo publicados, com mensagem que diz como gerar um segredo. Verificado com a aplicação empacotada: sem <code>JWT_SECRET</code> e com o valor de exemplo, a subida falha ; com um segredo próprio, sobe. Os testes de integração fornecem o próprio segredo (<code>IntegrationTestProperties</code>).
@Size(max = 72) conta caracteres; o BCrypt limita 72 bytes. Senha de 40 caracteres acentuados (80 bytes) passava na borda e fazia o codificador lançar <code>IllegalArgumentException</code> — o usuário não conseguia se cadastrar.	<code>@ValidPassword</code> : mínimo de 8 caracteres e máximo de 72 bytes em UTF-8 , com mensagem que explica o limite. O limite é detalhe do BCrypt e fica onde o BCrypt vive, na infraestrutura; aplicado aos três campos de senha nova. Testado com o motor de Bean Validation real e por HTTP (400, não 500).
PUT respondia com o lastUpdatedAt anterior à edição. O listener carimba o instante só no flush, e o registro era traduzido de volta antes disso. A asserção que pegaria o defeito tinha sido removida ao corrigir a precisão de nanossegundos.	<code>saveAndFlush</code> na origem de dados, para que a auditoria esteja aplicada quando o registro volta. O teste novo expôs ainda um desvio de 1 µs: o PostgreSQL guarda microssegundos e arredonda, e a resposta levava os nanossegundos do Java — por isso o <code>ClockDateTimeProvider</code> passou a carimbar já em microssegundos. Teste de integração: o instante devolvido é posterior ao anterior e exatamente igual ao gravado.
Falha de SMTP transformava o "esqueci minha senha" em oráculo de contas. Só há envio quando o e-mail existe; com o SMTP fora do ar, e-mail cadastrado dava 500 e desconhecido dava 202.	O contrato foi declarado na porta <code>IMailGateway</code> — falha de transporte não se propaga — e honrado por <code>SmtplibMailGateway</code> , que registra em ERROR sem o destinatário no log. Resposta vaga para o cliente, registro detalhado para quem opera. Verificado com a aplicação real e SMTP inexistente: 202 nos dois casos.
JwtTokenIssuer.read lançava NullPointerException em token assinado sem sub. O catch cobria <code>JwtException</code> e <code>IllegalArgumentException</code> , e <code>UUID.fromString(null)</code> escapava — 500 onde deveria ser 401.	<code>sub</code> e <code>login</code> passam a ser obrigatórios: ausência de qualquer um devolve vazio, como toda outra recusa. Testes com token assinado sem cada um deles.

Um resíduo ficou registrado como decisão consciente: o e-mail é enviado **dentro** da unidade de trabalho, então uma falha de commit depois do envio deixa o usuário com um token que não valida. É incômodo — basta pedir outro —, não é brecha, e o custo de um gancho pós-commit não se justifica nesta fase.

Verificação. `mvn verify`: **363 testes unitários** e **50 de integração** — **BUILD SUCCESS**. Cobertura pelos testes unitários: **848/848 linhas, 196/196 ramos, 372/372 métodos** — 100%.

Exceção de domínio ainda responde `500`: a tradução para `ProblemDetail` é a Etapa 8. Os testes de integração registram isso explicitamente onde esbarram no assunto.

Etapa 8 — Tratamento de Erros (`ProblemDetail`)

O `GlobalExceptionHandler` (`@RestControllerAdvice`, em `infrastructure/web/error`) traduz as exceções de domínio e as do próprio Spring para **`ProblemDetail` (RFC 9457, sucessora da 7807)**, com `timestamp` e um `type` próprio por categoria. Um `JwtAuthenticationEntryPoint` estende o padrão ao 401 de acesso sem token.

Exceção / situação	HTTP	type (urn:restaurantes:problema:...)	Detalhe na resposta
MethodArgumentNotValidException (Bean Validation)	400	requisicao-invalida	fixo, mais o mapa errors por campo
MethodArgumentTypeMismatchException ({id} não é UUID)	400	requisicao-invalida	cita o parâmetro, nunca o valor
HttpMessageNotReadableException (corpo malformatado)	400	requisicao-invalida	fixo — a mensagem do parser não sai
InvariantViolationException (invariante de entidade/VO)	400	requisicao-invalida	a mensagem do domínio
outra IllegalArgumentException (biblioteca)	400	requisicao-invalida	fixo; exceção no log em WARN
InvalidPasswordException	400	senha-invalida	a mensagem do domínio
InvalidOrExpiredTokenException	400	token-invalido	a mensagem do domínio
InvalidCredentialsException	401	falha-na-autenticacao	a mensagem do domínio (a mesma para login e senha)
acesso sem token (entry point)	401	nao-autenticado	fixo, igual para token ausente, expirado ou adulterado
ForbiddenOperationException	403	operacao-nao-permitida	a mensagem do domínio
AccessDeniedException (recurso de outro usuário)	403	acesso-negado	fixo
ResourceNotFoundException	404	recurso-nao-encontrado	a mensagem do domínio
DuplicateResourceException	409	conflito-de-dados	a mensagem do domínio
DataIntegrityViolationException (restrição única no banco)	409	conflito-de-dados	fixo, sem o nome da restrição; exceção no log em WARN
Exception (não prevista)	500	erro-inesperado	fixo; exceção completa no log em ERROR
demais exceções do Spring MVC (405, 415, rota inexistente)	conforme o caso	about:blank	o padrão do Spring, acrescido do timestamp

Princípio: resposta vaga para o cliente, registro detalhado para quem opera. Mensagens de parser ou de exceções internas nunca são repassadas na resposta.

Exemplo — cadastro com CEP de três dígitos (POST /api/v1/users):

```
{
  "type": "urn:restaurantes:problema:requisicao-invalida",
  "title": "Requisição inválida",
  "status": 400,
  "detail": "CEP deve ter 8 dígitos",
  "instance": "/api/v1/users",
  "timestamp": "2026-09-25T17:10:42.118"
}
```

O que foi entregue nesta etapa

Componente	Decisão e conceito que a sustenta
<code>GlobalExceptionHandler</code>	O único lugar que transforma "o que deu errado" em "que status e que corpo". O núcleo lança exceções de domínio sem saber que HTTP existe; os controllers não capturam nada. Estende <code>ResponseEntityExceptionHandler</code> para que as exceções do próprio Spring MVC (405, 415, rota inexistente) também saiam como <code>ProblemDetail</code> em vez de caírem no tratamento genérico como 500. Uma entrada por linha da tabela acima, cada uma legível e verificável isoladamente.
<code>InvariantViolationException</code> (domínio)	A especificação pedia duas coisas incompatíveis: <code>IllegalArgumentException</code> → 400 e nunca repassar mensagem interna. O <code>Guard</code> lança esse tipo com mensagens escritas para o usuário, mas bibliotecas também — o BCrypt diz "password cannot be more than 72 bytes", o <code>Assert</code> do Spring diz "'beans' must not be empty". A subclasse própria resolve sem heurística: a mensagem dela vai para a resposta, a das outras não. Estende <code>IllegalArgumentException</code> , então todo teste e todo código que já a tratavam como tal continuam certos; e fica em <code>domain/exception</code> , só com JDK.
<code>ProblemType</code>	Catálogo das categorias: <code>type</code> , título e status em um lugar só. O <code>type</code> é URN , e não URL: a RFC aceita identificadores não resolvíveis, e uma URL que não leva a lugar nenhum prometeria uma documentação que não existe. É nele — e não no título, que pode ser reescrito — que o cliente deve se apoiar.
<code>ProblemDetailFactory</code>	Um formato só para todas as respostas de erro, venham do handler ou da cadeia de segurança. O <code>timestamp</code> vem do <code>Clock</code> da aplicação: continua havendo um relógio só no sistema. Também carimba as respostas que o Spring monta sozinho.
<code>JwtAuthenticationEntryPoint</code>	O 401 é decidido na cadeia de filtros, antes do Spring MVC — fora do alcance do handler. Sem ele, seria a única resposta de erro sem corpo. O detalhe é o mesmo para token ausente, expirado ou adulterado.
Mapa <code>errors</code>	Campo → lista ordenada de mensagens. Um campo pode violar duas restrições ao mesmo tempo (senha vazia é "em branco" e "curta"), e a ordem das violações não é garantida: com mapa campo → texto único, a segunda colidiria com a primeira.
<code>spring.web.locale: pt_BR</code> fixo	As mensagens do Bean Validation seguem o idioma da requisição. Sem fixá-lo, a API responderia em português nesta máquina e em inglês dentro do container.
<code>DataIntegrityViolationException</code> → 409	Linha acrescentada à especificação. O caso de uso confere e-mail e login únicos antes de gravar, mas duas requisições simultâneas passam juntas pela conferência, e quem desempata é a restrição única do banco. É o mesmo conflito e recebe o mesmo 409 — sem o nome da restrição, que descreveria o schema.

Testes unitários — 26 casos em 4 classes, sem contexto Spring: cada exceção entra no handler e o que se verifica é o status, a categoria e, principalmente, **o que vai e o que não vai para o detalhe** — mensagem de biblioteca,

nome de restrição, texto do parser, valor do parâmetro inválido e nome da classe da exceção inesperada nunca aparecem.

Testes de integração — `ErrorHandlingIT`, **14 casos**, percorrendo a tabela por HTTP real: cada linha é provocada pelo caminho de verdade — Bean Validation, objeto de valor, caso de uso, `@PreAuthorize`, restrição do banco, roteamento do Spring — e a resposta é conferida no formato completo: `Content-Type: application/problem+json`, `type`, `title`, `status`, `detail`, `instance` e `timestamp` em ISO-8601. Os pontos que as etapas anteriores deixaram anotados como "vira isto na Etapa 8" foram apertados para o status exato: login com senha antiga → 401; token reutilizado → 400 `token-invalido`; consulta a cadastro excluído → 404.

Verificação. `mvn verify`: **389 testes unitários** e **64 de integração** — **BUILD SUCCESS**. Cobertura pelos testes unitários: **930/930 linhas**, **204/204 ramos**, **404/404 métodos** — 100%.

Etapa 9 — Documentação Swagger

OpenAPI gerada pelo springdoc a partir dos `@RestController` e dos DTOs HTTP. A `OpenApiConfig` registra o esquema de segurança Bearer JWT, habilitando o botão **Authorize**.

- Swagger UI: `http://localhost:8080/swagger-ui.html`
- OpenAPI JSON: `http://localhost:8080/v3/api-docs`

Como usar. Chame `POST /api/v1/auth/login` com o exemplo já preenchido (`admin.demo` / `admin12345`), copie o `token` da resposta, clique em **Authorize** e cole só o token — o prefixo `Bearer` é incluído. As operações protegidas têm um cadeado; o token fica guardado mesmo se a página for recarregada.

Ponto de partida: o documento gerado sem configuração estava errado

Antes de qualquer anotação, o documento que o springdoc publicava sozinho foi lido e comparado com a aplicação. Não era só incompleto — **afirmava coisas falsas**:

O que o documento dizia	O que a API faz
Nenhum esquema de segurança, nenhuma operação protegida	Cinco das nove operações exigem token
<code>POST /api/v1/users</code> responde 200	Responde 201 com <code>Location</code> — o springdoc não infere o status de um <code>ResponseEntity.created(...)</code>
Nenhuma resposta de erro	Cada operação tem de dois a seis casos de erro, todos em <code>ProblemDetail</code>
Título "OpenAPI definition", versão "v0"	—

Isso orientou a decisão central da etapa: documentação é **contrato**, e contrato que ninguém confere diverge do código em silêncio. Por isso a entrega não é só o documento, mas o documento **conferido contra a aplicação rodando**.

O que foi entregue nesta etapa

Componente	Decisão e conceito que a sustenta
<code>@ErrorResponse(type = ProblemType.X, description = "...")</code>	Cada caso de erro é declarado pela categoria , não pelo número. O código HTTP documentado sai de <code>ProblemType.status()</code> — o mesmo catálogo que o <code>GlobalExceptionHandler</code> usa para responder. Com <code>@ApiResponse(responseCode = "403")</code> o número seria uma cópia, e cópia envelhece; assim existe um lugar só onde "acesso negado é 403" está escrito, e documentação e comportamento não podem divergir.
<code>ErrorResponseOperationCustomizer</code>	Converte cada <code>@ErrorResponse</code> em resposta <code>ProblemDetail</code> com exemplo real da categoria (<code>type</code> , <code>title</code> , <code>status</code>). Casos com o mesmo código viram uma resposta só com um exemplo nomeado para cada um — a troca de senha documenta os dois <code>400</code> (senha atual incorreta e senha nova inválida), em vez de perder um deles.
<code>ProblemDetailOpenApiCustomizer</code>	Registra o esquema <code>ProblemDetail</code> , montado à mão: gerado a partir da classe do Spring, descreveria um mapa <code>properties</code> que a API nunca produz, porque em execução <code>timestamp</code> e <code>errors</code> saem achatados no corpo. O campo <code>type</code> é enumerado a partir do próprio <code>ProblemType</code> — o catálogo documentado é o mesmo que o handler usa. Serve ainda de rede de segurança: um erro declarado de outro jeito nunca fica documentado com o formato do tipo de retorno.
<code>ApiDocumentation</code> (pacote <code>web/doc</code>)	O nome do esquema de segurança é usado pela configuração e pelos controllers. Se morasse na <code>OpenApiConfig</code> , criaria um ciclo entre <code>config</code> e <code>web.user</code> — a <code>SecurityConfig</code> já importa os caminhos dos controllers. Num pacote neutro, as duas pontas dependem dele e nenhuma da outra: o Princípio das Dependências Acíclicas de Martin.
<code>@SecurityRequirement</code> por operação	O cadeado vai só nas cinco operações protegidas; o autocadastro e os três endpoints de autenticação ficam abertos, como na <code>SecurityConfig</code> .
<code>@ResponseStatus(CREATED)</code> no cadastro	Não muda o comportamento — o <code>ResponseEntity.created</code> já responde 201 —, mas é o que o springdoc lê. Sem ele, o documento seguiria dizendo 200.
Exemplos nos corpos de requisição	O <i>Try it out</i> vem preenchido com dados válidos: o login de exemplo é o administrador de demonstração, e o cadastro de exemplo passa em todas as validações.
<code>springdoc.swagger-ui</code>	Token preservado ao recarregar (<code>persist-authorization</code>), tags e operações em ordem estável, tempo de cada requisição visível.

Testes unitários — 22 casos em 2 classes (`ErrorResponseOperationCustomizerTest` , `ProblemDetailOpenApiCustomizerTest`), com documentos OpenAPI e controllers de exemplo montados no próprio teste.

Testes de integração — `OpenApiDocumentationIT` , 9 casos. Leem o documento que a aplicação publica e o confrontam com a aplicação rodando:

- **o cadeado bate com a segurança real** — cada operação é chamada sem token: a marcada como protegida tem de responder 401, e a marcada como pública não pode;
- **os exemplos funcionam** — um cadastro montado só com os exemplos do documento é aceito (201), e o login de exemplo autentica;
- **todo exemplo de erro é coerente** com o código da resposta em que aparece;

- o cadastro é documentado como 201, os nove endpoints estão presentes sob a tag certa, todo erro é ProblemDetail, e a interface do Swagger é pública.

Conferido também visualmente na aplicação empacotada: o Swagger UI mostra o cadeado nas cinco operações protegidas e o exemplo certo em cada código de erro.

Verificação. `mvn verify`: **411 testes unitários** e **73 de integração** — **BUILD SUCCESS**. Cobertura pelos testes unitários: **998/998 linhas, 222/222 ramos, 426/426 métodos** — 100%.

Etapa 10 — Execução com Docker Compose

Serviços

Serviço	Imagem	Porta no host (padrão)	Papel
app	construída pelo Dockerfile (<code>maven:3.9.16-eclipse-temurin-21-noble</code> → <code>eclipse-temurin:21.0.11_10-jre-alpine-3.23</code>)	APP_PORT (8080)	A API. Sobe depois que o banco está saudável.
db	<code>postgres:16.15-alpine3.24</code>	DB_PORT (5432)	Banco, com volume próprio <code>restaurantes-fase2_postgres_data</code> .
mailpit	<code>axllent/mailpit:v1.31.2</code>	MAILPIT_UI_PORT (8025 , web), MAIL_PORT (1025 , SMTP)	SMTP de testes: recebe os e-mails de redefinição de senha e os mostra em <code>http://localhost:8025</code> , sem entregar nada a ninguém.

Todas as portas são publicadas **só em** `127.0.0.1`: o banco usa senha de exemplo e a caixa do Mailpit mostra tokens de redefinição de senha — nenhum dos dois pode ficar alcançável pela rede local. Todas as imagens têm versão exata, sem tag móvel.

Variáveis de ambiente

Variável	Padrão	Descrição
JWT_SECRET	obrigatória, sem padrão	Segredo de assinatura do JWT (≥ 256 bits; o valor do <code>.env.example</code> é recusado de propósito)
JWT_EXPIRATION	3600000	Expiração do token em ms
DB_NAME	restaurantes-app	Nome do banco
DB_USER	postgres	Usuário do banco
DB_PASSWORD	postgres	Senha do banco
DB_HOST	localhost — no Compose, fixo em db	Host do banco
DB_PORT	5432	Porta do banco no host
MAIL_HOST	localhost — no Compose, fixo em mailpit	SMTP para recuperação de senha
MAIL_PORT	1025	Porta do SMTP no host
MAIL_FROM	no-reply@restaurantes.postech	Remetente
PASSWORD_RESET_TOKEN_EXPIRATION_MINUTES	30	Validade do token de redefinição (até a Etapa 12, <code>MAIL_RESET_TOKEN_EXPIRATION_MINUTES</code>)
APP_PORT	8080	Porta da API no host
MAILPIT_UI_PORT	8025	Porta da interface do Mailpit no host

`DB_HOST` e `MAIL_HOST` só valem para rodar a aplicação **fora** do Docker; dentro do Compose, ela fala com os serviços pelo nome, nas portas internas (`db:5432` , `mailpit:1025`). As portas do `.env` são as do **host**: a aplicação na IDE as usa para chegar aos serviços, e o Compose as usa para publicá-los — a mesma variável com o mesmo significado nos dois lados. Se a Fase 1 estiver rodando (ela ocupa `5432` e `8080`), basta `DB_PORT=5433` e `APP_PORT=8081` no `.env` . As credenciais de um SMTP real (`MAIL_USERNAME` , `MAIL_PASSWORD` , `MAIL_SMTP_AUTH` , `MAIL_SMTP_STARTTLS`) valem só fora do Docker: no Compose, o e-mail vai sempre para o Mailpit.

Passo a passo

```
# 1. Criar o .env e gerar um segredo JWT próprio (o do exemplo é recusado na subida)
cp .env.example .env
#   edite JWT_SECRET no .env — por exemplo, com o valor de: openssl rand -base64 48

# 2. Subir tudo: aplicação, banco e Mailpit (o primeiro build leva alguns minutos)
docker compose up --build

# 3. Conferir
#   API:      http://localhost:8080      (saúde: /actuator/health)
#   Swagger:  http://localhost:8080/swagger-ui.html
#   E-mails:  http://localhost:8025      (token de redefinição de senha)

# 4. Encerrar — os dados do banco são mantidos; com -v, são apagados
docker compose down
```

Para desenvolver com a aplicação na IDE, suba só os serviços de apoio com `docker compose up -d db mailpit`; os valores `localhost` do `.env.example` já apontam para eles.

Nome do projeto Compose

O `docker-compose.yml` declara `name: restaurantes-fase2` no topo. Sem isso o Compose deriva o nome do projeto da pasta (`restaurantes`) — o mesmo da Fase 1 —, e as duas fases passam a compartilhar o volume `restaurantes_postgres_data`. O efeito foi observado na Etapa 7: o banco da Fase 2 subiu sobre o histórico do Flyway da Fase 1 e a aplicação recusou iniciar por divergência de checksum. Com nome próprio, cada fase tem os próprios containers e volumes, e nenhuma apaga ou corrompe os dados da outra.

O Docker também é pré-requisito para `mvn verify`: os testes de integração da Etapa 11 sobem um PostgreSQL 16 via Testcontainers, com a mesma imagem, na mesma versão exata (`postgres:16.15-alpine3.24`), do `docker-compose.yml`.

O que foi entregue nesta etapa

Os arquivos de execução existiam desde a Etapa 1, mas nunca tinham sido executados de ponta a ponta. Revisados antes de rodar, tinham quatro problemas — e um quinto apareceu ao seguir o próprio passo a passo:

Componente	Decisão e conceito que a sustenta
<code>name: restaurantes-fase2</code> , sem <code>container_name</code>	Isola a Fase 2 da Fase 1 (ver acima). O <code>container_name</code> fixo também saiu: nome de container é global no Docker, e <code>restaurantes-db</code> colidiria com o container da Fase 1 mesmo com o projeto renomeado. O Compose gera nomes já prefixados (<code>restaurantes-fase2-db-1</code>).
Serviço <code>mailpit</code>	A recuperação de senha entrega o token só por e-mail — é o que a torna segura. Sem um SMTP, o recurso existia no código e era impossível de usar: o padrão anterior, <code>host.docker.internal:1025</code> , não tinha nada escutando. O Mailpit recebe os e-mails e os mostra numa interface, sem entregar nada a ninguém; é também o que a coleção Postman da Etapa 12 vai usar. Versão fixada (<code>v1.31.2</code>): <code>latest</code> faria o mesmo <code>docker compose up</code> produzir ambientes diferentes em dias diferentes.
<code>MAIL_HOST / MAIL_PORT</code> fixos no Compose	O defeito que o passo a passo revelou: o <code>.env.example</code> traz <code>MAIL_HOST=localhost</code> (para quem roda fora do Docker), e o Compose usava o <code>.env</code> para interpolar o host do SMTP. Dentro do container da aplicação, <code>localhost</code> é ela mesma — e como falha de SMTP não derruba a requisição (Etapa 7), todo e-mail se perderia em silêncio . Agora o SMTP do Compose é fixo, como o <code>DB_HOST</code> já era: dentro do Compose, os serviços se encontram pelo nome.
<code>Dockerfile</code>	Execução como usuário sem privilégio — se a aplicação for comprometida, o invasor não é root no container. Estágio de execução só com o JRE. Repositório Maven num cache do BuildKit, para o rebuild não baixar as dependências de novo; testes nem compilados na imagem. <code>HEALTHCHECK</code> no <code>/actuator/health</code> , decidido pelo código HTTP, com <code>start-period</code> cobrindo a subida do Spring e as migrations. Heap limitado a 75% da memória do container. Imagens base com versão exata.
<code>management.health.mail.enabled: false</code>	Com o indicador de e-mail ligado, o SMTP fora do ar faria o <code>/actuator/health</code> responder <code>503</code> , e o healthcheck daria o container como <code>unhealthy</code> por causa de um serviço opcional . Isso contradiria a decisão da Etapa 7, de que falha de SMTP é registrada e não derruba nada. A saúde fica com o que de fato impede a API de funcionar: banco (<code>db</code>) e disco (<code>diskSpace</code>). O <code>HealthIT</code> prova isso com um SMTP real e inalcançável. Com isso, o ajuste equivalente que o <code>AuthApiIT</code> fazia ficou redundante e saiu.
<code>.dockerignore</code> e <code>.env.example</code>	O contexto de build deixa de enviar o relatório e o PDF, e o <code>.env</code> nunca entra numa camada da imagem. O <code>.env.example</code> passa a dizer quais variáveis valem dentro e fora do Docker.

Revisão de código da etapa. Antes de fechar, o diff passou por uma revisão focada em falhas reais, que apontou nove pontos — um de segurança. Nenhuma etapa seguinte trata do ambiente de execução, então todos foram corrigidos aqui:

Achado	Correção e conceito
Portas publicadas em todas as interfaces. O Mailpit (8025 , 1025) e o PostgreSQL (5432 , senha de exemplo) ficavam alcançáveis pela rede local. Numa rede compartilhada, qualquer um pedia a redefinição de senha de outra pessoa e lia o token na interface do Mailpit.	Todas as portas presas a 127.0.0.1 . É a mesma regra da Etapa 7 — o token de redefinição só pode chegar ao dono do e-mail —, aplicada ao ambiente e não só ao código. Verificado com <code>docker compose port</code> .
Portas do host fixas, colidindo com a Fase 1. O nome do projeto separava volume e containers, mas 5432 e 8080 são recursos da máquina; com a Fase 1 rodando, o <code>up</code> falhava com <i>"port is already allocated"</i> , e trocar o <code>DB_PORT</code> no <code>.env</code> não mudava nada.	A porta do host vem do <code>.env</code> (<code>DB_PORT</code> , <code>APP_PORT</code> , <code>MAIL_PORT</code> , <code>MAILPIT_UI_PORT</code>). <code>DB_PORT</code> e <code>MAIL_PORT</code> passam a ter um significado só — a porta em que o serviço aparece no host —, o mesmo que a aplicação fora do Docker já usava. Verificado subindo a pilha em portas alternativas.
O <code>.env.example</code> listava credenciais de SMTP que o Compose não repassa. Quem as preenchesse para o Compose continuaria mandando e-mail para o Mailpit sem saber.	As credenciais foram para a seção "só fora do Docker", com a regra escrita no <code>.env.example</code> , no <code>docker-compose.yml</code> e na tabela de variáveis: o Compose é o ambiente de demonstração, e provedor real é configuração de quem roda fora.
A saúde sem o e-mail não tinha teste. A regra era garantida só indiretamente, pelo contexto do <code>AuthApiIT</code> .	<code>HealthIT</code> , com SMTP real apontado para uma porta onde nada escuta: a saúde é <code>UP</code> e <code>200</code> ; é pública sem expor componentes; e, autenticado, mostra <code>db</code> e <code>diskSpace</code> , sem <code>mail</code> . Conferido ao contrário: religando o indicador, os três testes falham (<code>503</code>).
A documentação dizia que a saúde dependia só do banco e que um orquestrador reiniciaria o container. O Actuador também conta o disco, e o Compose não reinicia container <code>unhealthy</code> .	Texto corrigido no <code>application.yml</code> , no <code>CLAUDE.md</code> e nesta seção: banco e disco, e o efeito real é o container marcado <code>unhealthy</code> .
-DskipTests ainda compilava todos os testes na imagem. Custo a cada build, e um teste que não compilasse quebraria o <code>docker compose up</code> .	<code>-Dmaven.test.skip=true</code> : os testes nem compilam na imagem; quem os roda é o <code>mvn verify</code> .
A camada de <code>dependency:go-offline</code> não cobria tudo o que o <code>package</code> usa , e parte das dependências era baixada de novo a cada build.	O repositório Maven fica num cache do BuildKit (<code>RUN --mount=type=cache</code>), que sobrevive entre builds independentemente de qual camada mudou.
O healthcheck dependia do formato do JSON (<code>grep '"status":"UP"'</code>), embora o Actuador já responda <code>503</code> quando algo está <code>DOWN</code> .	<code>wget</code> sem <code>grep</code> : o código de saída já é o veredito. Um ajuste de formatação do JSON não pode derrubar um container saudável.
Só o Mailpit tinha versão fixada. A justificativa escrita para ele — o mesmo <code>up</code> produzir o mesmo ambiente — valia igual para <code>postgres:16-alpine</code> e para as imagens base do <code>Dockerfile</code> , que eram tags móveis.	Versão exata em todas: <code>postgres:16.15-alpine3.24</code> , <code>maven:3.9.16-eclipse-temurin-21-noble</code> , <code>eclipse-temurin:21.0.11_10-jre-alpine-3.23</code> (as mesmas que as tags móveis resolviam na verificação, conferidas pelo digest). O Testcontainers usa a mesma versão do Postgres do Compose: o banco dos testes é o banco em que a aplicação roda. Regra aplicada com consistência, não só onde foi escrita.

De passagem, o `autenticar` que `UserApiIT` e `ErrorHandlingIT` repetiam foi para a `WebIntegrationTestSupport` , em vez de ganhar uma terceira cópia no `HealthIT` .

Verificação — o passo a passo executado literalmente, contra os containers:

Passo	Resultado
<code>cp .env.example .env</code> e <code>docker compose up --build</code> sem trocar o segredo	<code>db</code> e <code>mailpit</code> saudáveis; <code>app</code> encerra com " <i>Segredo do JWT é o valor de exemplo publicado no repositório; gere um próprio...</i> " — a recusa é clara e diz o que fazer
Segredo gerado com <code>openssl rand -base64 48</code> e <code>docker compose up</code>	os três serviços <code>healthy</code> ; o processo da aplicação roda como <code>app</code> , não <code>root</code>
Swagger UI, <code>/actuator/health</code> , login do administrador e listagem	<code>200</code> , <code>{"status": "UP"}</code> , <code>200</code> , <code>200</code>
Cadastro → "esqueci minha senha" → token lido no e-mail do Mailpit → redefinição → login com a senha nova / com a antiga	<code>201</code> → <code>202</code> → token de 43 caracteres → <code>204</code> → <code>200</code> / <code>401</code>
<code>docker compose down</code> e <code>up</code>	o usuário cadastrado continua lá; o Flyway reporta " <i>Schema is up to date. No migration necessary</i> "
<code>docker compose down -v</code>	remove <code>restaurantes-fase2_postgres_data</code> ; o volume e o container da Fase 1 continuam intactos

Verificação das correções da revisão, de novo contra os containers:

Passo	Resultado
Build da imagem com o cache do BuildKit vazio / depois de alterar uma classe	2min47s / 20s — a alteração de código não baixa dependência nenhuma
<code>.env</code> com <code>APP_PORT=18080</code> , <code>DB_PORT=15432</code> , <code>MAIL_PORT=11025</code> , <code>MAILPIT_UI_PORT=18025</code> e <code>docker compose up</code>	os três serviços <code>healthy</code> , publicados em <code>127.0.0.1:18080</code> , <code>127.0.0.1:15432</code> , <code>127.0.0.1:11025</code> e <code>127.0.0.1:18025</code>
As mesmas portas pelo IP de rede da máquina / por <code>127.0.0.1</code>	recusadas / alcançáveis
Recuperação de senha completa nas portas alternativas, com o token lido no Mailpit	<code>201</code> → <code>202</code> → token de 43 caracteres → <code>204</code> → senha nova <code>200</code> / antiga <code>401</code>
Mailpit parado por 45 s	<code>app</code> continua <code>healthy</code> , <code>/actuator/health</code> <code>200</code>
Banco parado / de volta	<code>app</code> fica <code>unhealthy (503)</code> / volta a <code>healthy</code> sozinha
<code>docker compose config</code> com o <code>.env.example</code>	portas padrão <code>8080</code> , <code>5432</code> , <code>8025</code> , <code>1025</code> , todas em <code>127.0.0.1</code>

`mvn verify` segue verde — **411 testes unitários** e **76 de integração** (os 3 novos do `HealthIT`), cobertura 100% (998/998 linhas, 222/222 ramos). Nenhuma classe Java de produção nova nesta etapa: a entrega é o ambiente de execução e a sua verificação.

Etapa 11 — Testes: unitários (100% de cobertura) e de integração

A suíte tem **dois compromissos**, ambos verificados no build:

- Testes unitários com 100% de cobertura.** Toda linha e todo ramo de `domain` , `application` e `adapter` — e das classes de `infrastructure` que contêm lógica — são exercitados por testes unitários isolados, sem contexto

Spring e sem banco. A meta é imposta pelo JaCoCo: o `mvn verify` **falha** se a cobertura de linhas ou de ramos ficar abaixo de 100%.

2. **Testes de integração que provam que a aplicação funciona.** Com o contexto Spring completo, PostgreSQL real (Testcontainers), migrations aplicadas pelo Flyway, segurança JWT ativa e requisições HTTP de verdade, cada endpoint é exercitado de ponta a ponta — do `@RestController` ao banco e de volta. Eles garantem que os componentes que os testes unitários isolaram por mocks realmente se encaixam.

A arquitetura torna os dois compromissos viáveis: como as camadas internas não conhecem framework, os testes unitários são rápidos e não precisam de infraestrutura; e como toda a infraestrutura está em um só pacote, os testes de integração sabem exatamente o que precisam subir.

Testes unitários (cobertura 100%)

Nível	Classes de teste	Ferramentas	Característica
Entidades e VOs	UserTest , RoleTest , RoleNameTest , AddressTest , PasswordResetTokenTest , EmailTest , ZipCodeTest , GuardTest , DomainExceptionsTest	JUnit 5	Sem mocks. Cada invariante tem um teste que prova que a entidade o recusa (assertThrows) e um que prova que aceita o valor válido.
DTOs do núcleo	PageRequestTest , PageResultTest , DtoTest	JUnit 5	Limites de paginação, cálculo de páginas, hasNext / hasPrevious , validação do IssuedToken .
Casos de uso	um *UseCaseTest por intenção do ator (UserQueryUseCasesTest reúne busca por id, listagem e exclusão)	JUnit 5 + Mockito	Mocks das interfaces I*Gateway ; sem contexto Spring. Um comportamento por teste; todo if tem os dois caminhos cobertos.
Adaptadores	UserControllerTest , AuthControllerTest , UserGatewayTest , RoleAndTokenGatewaysTest , PresentersTest	JUnit 5 + Mockito	Mocks de I*DataSource ; verifica tradução entidade ↔ record e a orquestração do controller (unidade de trabalho → caso de uso → presenter).
Infraestrutura com lógica	persistência (UserDataSourceJpaTest , RoleAndTokenDataSourcesJpaTest , JpaEntitiesTest , TransactionalUnitOfWorkTest , AuthenticatedAuditorAwareTest , ClockDateTimeProviderTest); segurança HTTP (BearerTokenAuthenticationFilterTest , ProblemDetailAuthenticationEntryPointTest , SecurityComponentsTest , AuthenticatedActorTest); token (JwtTokenIssuerTest); criptografia (CryptoComponentsTest); e-mail (SmtptMailGatewayTest); composição (PasswordResetPropertiesTest); web (UserRestControllerTest , AuthRestControllerTest , UserWebMappingTest , ValidPasswordTest , GlobalExceptionHandlerTest , ProblemDetailFactoryTest); OpenAPI (ErrorResponseOperationCustomizerTest , ProblemDetailOpenApiCustomizerTest)	JUnit 5 + Mockito	Classes instanciadas diretamente, com JpaRepository , SecurityContext e MailSender mockados. Configurações puramente declarativas (infrastructure/**/*Config) são excluídas do cálculo.
Arquitetura	ArchitectureTest (14 regras)	ArchUnit	Regra de dependência e nomenclatura do código de produção.
Convenções da suíte	TestConventionsTest (7 regras)	ArchUnit	As convenções abaixo, verificadas sobre as próprias classes de teste.

Como o 100% é imposto. O jacoco-maven-plugin roda a regra check de LINE e BRANCH em 1.00 na fase verify . O gate é **dos testes unitários**: o Surefire e o Failsafe recebem agentes distintos, que gravam arquivos distintos (jacoco.exec e jacoco-it.exec), e o check lê só o primeiro. A cobertura da integração sai em relatório separado, informativo (target/site/jacoco-it). Os dois agentes usam append=false , para que nenhum arquivo

acumule execuções anteriores. As únicas exclusões são `RestaurantesApplication` e as classes `infrastructure/**/*Config`, que só declaram beans (regra verificada desde a Etapa 13) — tudo o que contém um `if`, um `map` ou uma exceção entra na conta.

```
<configuration>
  <excludes>
    <exclude>**/RestaurantesApplication.class</exclude>
    <exclude>**/infrastructure/**/*Config.class</exclude>
  </excludes>
</configuration>
<executions>
  <execution>                                <!-- testes unitários: alimentam o gate -->
    <id>prepare-agent</id>
    <goals><goal>prepare-agent</goal></goals>
    <configuration><append>>false</append></configuration>
  </execution>
  <execution>                                <!-- testes de integração: outro arquivo, fora do gate -->
    <id>prepare-agent-integration</id>
    <goals><goal>prepare-agent-integration</goal></goals>
    <configuration><append>>false</append></configuration>
  </execution>
  <execution>
    <id>check-coverage</id>
    <phase>verify</phase>
    <goals><goal>check</goal></goals>
    <configuration>
      <rules>
        <rule>
          <element>BUNDLE</element>
          <limits>
            <limit><counter>LINE</counter><value>COVEREDRATIO</value><minimum>1.00</minimum></limit>
            <limit><counter>BRANCH</counter><value>COVEREDRATIO</value><minimum>1.00</minimum></limit>
          </limits>
        </rule>
      </rules>
    </configuration>
  </execution>
</executions>
```

Testes de integração (componentes funcionando juntos)

Todos estendem uma de duas bases, que apontam para um único contêiner PostgreSQL `16.15-alpine3.24` compartilhado pela suíte (`Testcontainers`, `@ServiceConnection`, iniciado em bloco `static` — ver `SharedPostgres`) e fornecem o segredo do JWT de teste: `IntegrationTestSupport` (`@SpringBootTest` sem servidor, para a persistência) e `WebIntegrationTestSupport` (`RANDOM_PORT` + `TestRestTemplate`, para as chamadas HTTP). O Flyway aplica as migrations reais; a segurança JWT fica ativa. Nenhum bean da aplicação é substituído, exceto o `JavaMailSender`: o `SmtpMailGateway` **real** roda e monta o e-mail, e o dublê só captura o que seria enviado — o teste lê o token do corpo do e-mail, como o usuário faria.

Suíte	O que garante
SchemaMigrationIT	Migrations V1–V2 aplicadas e registradas; exatamente as cinco tabelas; catálogo com os três papéis; usuários de demonstração com papel, senha em hash e <code>created_by = system</code> ; <code>ON DELETE CASCADE</code> agindo no banco por SQL direto. O contexto só sobe se o <code>ddl-auto: validate</code> aceitar o mapeamento JPA contra esse schema.
UserPersistenceIT	Persistência do agregado contra o banco real: leitura inteira com papéis e endereços, reconstrução de entidade válida, busca por login e e-mail, substituição de endereços sem órfãos, N:M de papéis sem tocar no catálogo, identidade preservada na atualização, instante de alteração devolvido igual ao gravado, busca paginada sem diferenciar maiúsculas, ordenação traduzida, propriedade não permitida caindo no nome, exclusão em cascata.
PasswordResetTokenPersistenceIT	Token recuperado pelo hash, consumo gravado, hash único, cascata na exclusão do dono.
TransactionalUnitOfWorkIT	O bloco concluído confirma todas as escritas; exceção no meio desfaz também o que já havia sido gravado.
HealthIT	<code>/actuator/health</code> público, sem expor componentes a anônimo; <code>UP</code> com o SMTP real inalcançável; componentes <code>db</code> e <code>diskSpace</code> , sem <code>mail</code> .
JwtAuthenticationIT	Token do administrador expirado, assinado com outra chave ou sem assinatura (<code>alg: none</code>) → <code>401</code> ; o mesmo formato com a chave certa e dentro da validade → <code>200</code> (controle).
AuthApiIT	Login da seed (<code>200</code> , JWT com expiração); senha errada e login inexistente com a mesma resposta; "esqueci minha senha" com <code>202</code> para e-mail existente, inexistente e com SMTP fora do ar; redefinição com o token lido do e-mail (<code>204</code>), senha antiga deixando de valer; token reusado e token vencido (<code>400 token-invalid</code>).
UserApiIT	Cadastro público (<code>201</code> + <code>Location</code> , sem senha no corpo); <code>401</code> sem token ou com token malformatado; posse (<code>403</code> no cadastro alheio, <code>200</code> para o dono e o administrador); listagem só do administrador; senha de 80 bytes recusada na borda; atualização preservando senha e papéis; autor da auditoria em cada gravação (<code>system</code> no autocadastro, depois quem alterou); troca de senha; exclusão.
UserSearchIT	Busca por trecho do nome sem diferenciar maiúsculas; o cliente percorre todas as páginas seguindo os links <code>next</code> , e <code>first / prev / last</code> apontam para onde devem; ordenação decrescente chega ao banco; <code>sort=password</code> ignorado (<code>200</code> , ordenação padrão); tamanho de página fora do limite → <code>400</code> .
UserLifecycleIT	O cenário principal de sucesso encadeado: cadastro → login → consulta pelo <code>Location</code> → atualização (endereço substituído, senha preservada) → troca de senha → pedido de redefinição pendente → exclusão → <code>404</code> e login recusado — e, no banco, nenhuma linha restante em <code>users</code> , <code>addresses</code> , <code>user_roles</code> e <code>password_reset_tokens</code> .
ErrorHandlingIT	Cada categoria da Etapa 8 como <code>ProblemDetail</code> com <code>type</code> , <code>title</code> , <code>status</code> , <code>detail</code> , <code>instance</code> e <code>timestamp</code> : validação (<code>400</code> com o mapa <code>errors</code>), corpo malformatado, id que não é UUID, invariante do domínio, papel inexistente, senha atual incorreta, token desconhecido, credenciais erradas, sem token, <code>ROLE_ADMIN</code> no autocadastro, cadastro alheio, inexistente, e-mail repetido, método não suportado.
OpenApiDocumentationIT	O documento declara os nove endpoints e o esquema Bearer; o cadeado de cada operação bate com o <code>401</code> real; exemplos de erro coerentes com o código; os exemplos de corpo são aceitos pela API; Swagger UI público.

O `500` genérico (exceção inesperada, sem vaziar a mensagem) é provado no teste unitário do `GlobalExceptionHandler`, não por HTTP: provocá-lo de fora exigiria substituir um bean da aplicação, justamente o que a convenção proíbe.

Os testes de integração têm sufixo `IT` e rodam na fase `integration-test` via `maven-failsafe-plugin`, separados dos unitários (`maven-surefire-plugin`, fase `test`). Assim `mvn test` continua rápido (unitários + ArchUnit, sem Docker) e `mvn verify` executa tudo e aplica a regra de cobertura.

```
mvn test      # unitários + ArchUnit (segundos, sem Docker)
mvn verify    # + integração com Testcontainers + verificação de 100% de cobertura
```

Convenções

As marcadas com ✓ são verificadas no build pelo `TestConventionsTest`; as demais, na revisão.

- Estrutura **arrange / act / assert** em todo teste, com os três blocos visíveis.
- ✓ `@DisplayName` em todo `@Test` e `@ParameterizedTest`, descrevendo a regra em linguagem de negócio (`"Recusa autocadastro com ROLE_ADMIN"`, não `testRegister3`).
- ✓ Nomes de método `deve<Comportamento>[Quando<Condição>]`, ou `naoDeve...` para a negação.
- ✓ Um teste unitário (`*Test`) **nunca** sobe contexto Spring nem toca em banco: não depende de `Testcontainers`, `spring-boot-test`, contexto de teste do Spring nem JDBC.
- ✓ Todo teste de integração (`*IT`) estende uma das duas bases, e **nunca** substitui um bean da aplicação: `@MockitoBean` só em `JavaMailSender`, `@MockitoSpyBean` em nada.
- ✓ Nenhuma classe usa `@Testcontainers`: o contêiner é único e compartilhado.
- Testes independentes entre si. O banco é compartilhado e **não é limpo** entre classes: cada teste cria os próprios dados com uma marca única e consulta só por ela. Isolar por transação não serviria aos testes HTTP — a requisição roda em outra thread, com transação própria, e o rollback do teste não a alcançaria. A independência é conferida rodando a suíte inteira em ordem aleatória de classes e de métodos:

```
mvn verify -Djunit.jupiter.testclass.order.default='org.junit.jupiter.api.ClassOrderer$Random' \
           -Djunit.jupiter.testmethod.order.default='org.junit.jupiter.api.MethodOrderer$Random' \
           -Djunit.jupiter.execution.order.random.seed=2026
```

Regras de arquitetura (ArchUnit)

Regra (<code>ArchitectureTest</code>)	Protege
camadas concêntricas só apontam para dentro (DSL de <i>onion architecture</i>)	a regra de dependência como um todo
<code>domain</code> não depende de nenhum outro pacote do projeto	pureza das entidades
<code>application</code> depende apenas de <code>domain</code>	casos de uso sem infraestrutura
<code>adapter</code> não depende de <code>infrastructure</code>	adaptadores agnósticos de framework
Spring, JPA, Hibernate, springdoc, jjwt, Bean Validation, Jakarta Mail e Flyway só em <code>infrastructure</code>	os frameworks como detalhe
classes em <code>..usecase..</code> têm sufixo <code>UseCase</code> e <code>run</code> como único método público de instância	um caso de uso, uma intenção do ator
tipos em <code>application.gateway</code> são interfaces com prefixo <code>I</code>	convenção das portas do núcleo
tipos em <code>adapter.datasource</code> são interfaces com prefixo <code>I</code>	contrato da origem de dados
tipos em <code>adapter.datasource.data</code> são records com sufixo <code>Data</code>	registro da origem de dados é só dado
tipos em <code>adapter.presenter.view</code> são records com sufixo <code>View</code>	saída do núcleo passa pelo presenter
classe anotada com <code>@Entity</code> reside em <code>infrastructure.persistence.jpa</code>	ORM nunca anota entidade de domínio
o sufixo <code>JpaEntity</code> é exclusivo desse pacote	entidade JPA não se confunde com a de domínio
toda implementação de <code>I*DataSource</code> termina em <code>DataSourceJpa</code>	persistência é detalhe substituível
toda classe em <code>adapter.gateway</code> implementa uma interface de <code>application.gateway</code>	gateway sempre tem porta no núcleo

O que foi entregue nesta etapa

As etapas anteriores entregaram os testes junto com o código, como exige o gate de 100%. Esta etapa foi uma **auditoria da suíte contra a especificação acima**, escrita antes do código: cada garantia prometida foi procurada num teste que de fato a verificasse. A especificação previa oito suítes com outros nomes (`ApplicationContextIT` , `AuthFlowIT` , `ErrorContractIT` ...); a suíte real se organizou pelo pacote que exercita, e as tabelas acima passaram a descrever o que existe. O que a auditoria encontrou:

Achado	O que foi feito e conceito que o sustenta
O gate de 100% não media só os testes unitários. O Surefire e o Failsafe recebiam o mesmo agente do JaCoCo, gravando no mesmo arquivo: uma linha coberta só por teste de integração passava no <code>check</code> . Provado rodando um único <code>*IT</code> , sem nenhum unitário — o <code>check</code> leu 28% de cobertura vinda dele. E o arquivo acumulava execuções anteriores: um teste apagado continuaria "cobrindo" pelos dados velhos.	Agentes e arquivos separados (<code>jacoco.exec</code> para o gate, <code>jacoco-it.exec</code> informativo) e <code>append=false</code> . É o compromisso 1 como a especificação o escreve: 100% pelos testes unitários , rápidos e isolados (F.I.R.S.T., <i>Clean Code</i> cap. 9). Com a medição corrigida, o resultado se manteve em 100% — a cobertura nunca dependeu da integração, e agora o build prova isso.
A listagem não tinha links de navegação. A página devolvia só <code>users</code> ; a especificação (e a tabela de tecnologias: "links de navegação nas respostas REST") prometia <code>first / next / last</code> . Sem eles, o cliente precisa montar URL para paginar.	<code>UserModelAssembler</code> passa a dar <code>self</code> , <code>first</code> , <code>last</code> e, quando existem, <code>prev / next</code> , repetindo a busca e a ordenação pedidas. Os parâmetros chegam decodificados e são codificados uma só vez — reaproveitar a query string crua codificaria de novo o que já veio codificado (testado com <code>João & Maria</code>). A regra de "tem próxima/anterior" já era do núcleo (<code>PageResult.hasNext / hasPrevious</code>); o canal só a traduz em link.
"Token inválido ou expirado" só testava lixo. O teste mandava <code>token.que.nao.vale</code> ; nenhum teste provava que um token expirado ou forjado com outra chave é recusado — os dois ataques que importam.	<code>JwtAuthenticationIT</code> : expirado, outra chave e <code>alg: none</code> , todos se passando pelo administrador, contra a listagem administrativa; e um controle com o mesmo formato e a chave certa, que responde <code>200</code> . Sem o controle, os três passariam também se o token do teste estivesse apenas malformatado. O teste antigo foi renomeado para o que de fato verifica.
Busca por HTTP sem teste de ponta a ponta. Busca parcial, maiúsculas, ordenação proibida e navegação só eram provadas na persistência, não do parâmetro da URL até o <code>ORDER BY</code> .	<code>UserSearchIT</code> , incluindo o cliente que percorre as páginas só seguindo links . Revelou uma expectativa errada minha, não um defeito: <code>sort=password,desc</code> volta em ordem crescente — o caso de uso descarta o pedido inteiro, direção inclusive, como a Etapa 3 especifica.
Token de redefinição vencido, senha preservada na atualização e autor da auditoria não tinham teste por HTTP.	<code>AuthApiIT</code> ganhou o token vencido (o vencimento é empurrado para trás no banco; quem decide que venceu continua sendo a aplicação). <code>UserApiIT</code> ganhou a senha e os papéis preservados no <code>PUT</code> e o autor gravado em cada alteração. Este último mostrou um comportamento que vale registrar: um <code>PUT</code> idêntico ao estado gravado não gera <code>UPDATE</code> , e o autor anterior continua — "última alteração" é de dado, não de pedido.
Nenhum teste encadeava o ciclo de vida. Cada passo era provado isolado; nada provava que o estado deixado por um é o que o seguinte precisa, nem que a exclusão não deixa órfãos.	<code>UserLifecycleIT</code> : o cenário principal de sucesso de Cockburn, do cadastro à exclusão, conferindo no banco que nada restou nas quatro tabelas.
Convenções só no papel. <code>@DisplayName</code> , nome <code>deve...</code> , unitário sem contexto, integração sem dublê de bean — tudo escrito no <code>CLAUDE.md</code> , nada verificado. A auditoria achou os 393 testes em conformidade (12 usam <code>naoDeve...</code> , negação natural da convenção, agora aceita por escrito).	<code>TestConventionsTest</code> , 7 regras <code>ArchUnit</code> sobre as classes de teste , no mesmo espírito da regra de dependência: convenção que o build não verifica vale até o primeiro esquecimento. Conferido ao contrário, com arquivos que violavam de propósito cinco delas: as cinco falharam.
A regra de caso de uso não conferia o <code>run</code>. A especificação diz "sufixo <code>UseCase</code> e método público <code>run</code> "; a regra só olhava o sufixo.	A regra passou a exigir <code>run</code> como único método público de instância: um caso de uso é uma intenção do ator, e um segundo método público seria outro caso de uso escondido. Os nove já cumpriam.

Achado	O que foi feito e conceito que o sustenta
Independência declarada, não verificada.	A suíte inteira rodou em ordem aleatória de classes e de métodos com duas sementes (11 e 2026), confirmado pela ordem das classes no log: verde nas duas.
Texto da especificação desatualizado. Citava <code>JwtService</code> e <code>AuditorProvider</code> (hoje <code>JwtTokenIssuer</code> e <code>AuthenticatedAuditorAware</code>), "projeção sem <code>password</code> " (a leitura traz o agregado inteiro e quem esconde a senha é o presenter — Etapa 5), " <code>IMailGateway</code> em memória" (o dublê é o <code>JavaMailSender</code> , e o gateway real roda) e "isolados por transação" (impossível nos testes HTTP).	Texto alinhado ao código, com a razão de cada diferença.

Verificação. `mvn clean verify` : **422 testes unitários** (411 + 4 do assembler + 7 regras de convenção) e **89 de integração** (76 + 13 novos) — **BUILD SUCCESS**. Cobertura **só dos testes unitários**, agora medida em separado: **1016/1016 linhas, 226/226 ramos, 427/427 métodos** — 100%. A integração, sozinha, cobre 956/1016 linhas (94%) e 151/226 ramos (67%); os ramos que ela não alcança são, em sua maioria, recusas defensivas que só um teste unitário provoca (argumento nulo, falha de biblioteca), e é por isso que os dois compromissos existem.

Etapa 12 — Entregáveis (Postman, README)

- **Coleção Postman** (`postman/Restaurantes.postman_collection.json` , formato v2.1), com um request por caso de cada endpoint — sucesso e cada erro previsto — e scripts de teste que salvam `{{token}}` , `{{adminToken}}` e `{{userId}}` para execução de cima a baixo. Validada com Newman contra a aplicação em execução.
- **Prints** de cada request em `postman/prints/` , gerados a partir da mesma execução.
- **README** com stack, pré-requisitos, execução com Docker Compose, variáveis de ambiente, fluxo de autenticação, tabela de endpoints, Swagger, uso da coleção e execução dos testes.

O que foi entregue nesta etapa

Componente	Decisão e conceito que a sustenta
Coleção Postman — 52 requests em 9 pastas	Uma pasta por operação, e dentro dela o cenário principal de sucesso seguido de cada extensão de erro — a mesma organização de Cockburn que a especificação dos casos de uso seguiu. Os casos vêm do próprio catálogo <code>@ErrorResponse</code> da Etapa 9, o mesmo que a OpenAPI publica: coleção, documentação e handler descrevem os mesmos erros. Cada request confere o status e, nos erros, o <code>type</code> do <code>ProblemDetail</code> — o identificador em que o cliente se apoia (Etapa 8).
Execução de cima a baixo, repetível	Cada execução cria os próprios usuários, com login e e-mail únicos, e os exclui ao fim: roda quantas vezes quiser contra o mesmo banco (o <i>R</i> de F.I.R.S.T., <i>Clean Code</i> cap. 9). Requisição essencial — login, cadastro — confere o status <i>antes</i> de ler o corpo e, se falhar, interrompe a execução com o motivo, em vez de gravar <code>undefined</code> como token e deixar dezenas de falhas sem relação aparente com a causa.
Casos de acesso negado miram um cadastro descartável	Os <code>403</code> de consulta, atualização, troca de senha e exclusão usam um segundo cliente criado pela própria coleção, nunca um usuário da seed. Um teste de autorização existe para o dia em que a regra regredir — e nesse dia ele não pode ser o agente do dano (<i>The Clean Coder</i> : primeiro, não causar mal). O administrador exclui esse cadastro ao fim, o que também cobre o sucesso da exclusão administrativa.
Recuperação de senha pelo Mailpit	O token só existe no e-mail (Etapa 7). A coleção faz o que o usuário faria: busca a mensagem na API do Mailpit e lê o token no corpo. Assim o fluxo completo — pedir, confirmação divergente, token desconhecido, redefinir, reusar, entrar com a senha nova — roda sem intervenção.
Prints (<code>postman/prints/</code> , 52)	Gerados por <code>postman/gerar-prints.js</code> a partir de uma execução do Newman , como a especificação pede: cada imagem é o request, a resposta e os testes daquela chamada (tokens abreviados). O Chrome headless mede a altura real da página antes de fotografá-la. Os prints antigos só são substituídos depois que todos os novos forem gerados; request sem resposta vira um print que mostra a falha. O script está versionado para que restaurante e cardápio entrem na coleção e nos prints do mesmo jeito.
README	Descreve o que existe : restaurante, cardápio e o CRUD do catálogo de tipos de usuário aparecem como pendentes, em vez de prometidos. Passo a passo com a geração do segredo JWT (<code>openssl</code> ou PowerShell, testados), usuários da seed, regras de acesso, endpoints, catálogo de erros, uso da coleção com a versão validada do Newman (<code>newman@6</code>) e testes. Para rodar fora do Docker, diz como carregar o <code>.env</code> — Maven e IDE não o leem, e sem isso uma porta trocada no <code>.env</code> levaria a aplicação a outro PostgreSQL.

Revisão de código da etapa. O diff passou por uma revisão focada em falhas reais, que apontou dez pontos, todos corrigidos antes de fechar:

Achado	Correção
Os 403 miravam <code>cliente.demo</code> , da seed, e a troca de senha enviava a senha real dele: com a regra de posse regredida, a coleção trocava a senha e excluía o usuário de demonstração.	Segundo cadastro descartável como alvo; a seed nunca é tocada. Conferido: depois de duas execuções, <code>cliente.demo</code> entra normalmente e nenhum cadastro da coleção sobra no banco.
O gerador de prints apagava os prints antes de saber se o Chrome funcionava — com o caminho padrão (só Windows), apagaria os 50 e quebraria.	Confere o Chrome e os argumentos antes de tudo; gera numa pasta temporária e só então substitui. Conferido com <code>CHROME_PATH</code> inválido: recusa com mensagem, 50 prints antes e depois.
O gerador quebrava em request sem resposta (<code>ECONNREFUSED</code>).	O print mostra "sem resposta" e o motivo (<code>connect ECONNREFUSED 127.0.0.1:1</code>).
O README mandava rodar <code>mvn spring-boot:run</code> "com as variáveis do <code>.env</code> ", que o Maven não lê.	Comandos para exportar o <code>.env</code> em bash e PowerShell, ambos conferidos.
O relatório não tinha sido atualizado na etapa.	Esta seção,  no Sumário de Progresso e contador 12/12.
Login que falhasse gravava "undefined" como token, e tudo depois falhava em cascata.	Requisições essenciais interrompem a execução. Conferido com a API apontada para outro serviço: para no primeiro request, com <code>adminToken</code> não foi obtido (status 405). Revelou ainda que o script lia o corpo antes do status — uma resposta que não fosse JSON o quebrava antes de ele poder parar.
O mapa de pastas do gerador supunha exatamente dois níveis.	Percorre pastas em qualquer profundidade e aceita request na raiz.
<code>npx newman</code> sem versão.	<code>newman@6</code> no README e na descrição da coleção.
A pasta temporária do gerador nunca era removida.	Removida em <code>finally</code> , mesmo quando a geração falha.
Nada dizia como gerar os prints de novo.	Comandos no README e no <code>CLAUDE.md</code> .

Observado na execução. Um `DELETE /api/v1/auth/login` **sem** token responde 401, não 405: só o `POST` das rotas de autenticação é público, e a segurança decide antes do roteamento — um anônimo não descobre quais métodos existem. O caso de 405 da coleção usa o token do administrador. E as exceções do próprio Spring MVC (405, 415, rota inexistente) saem com `type: about:blank` e título em inglês, como a Etapa 8 decidiu — válido pela RFC 9457, mas é o único ponto em que a API não fala português.

Verificação. Com a pilha do Docker Compose no ar, `npx newman@6 run` executou os **52 requests** com **108 asserções** e **nenhuma falha**, duas vezes seguidas; os prints são da segunda. A versão anterior da coleção também foi executada com a aplicação fora do Docker (`mvn spring-boot:run` contra o banco e o Mailpit do Compose), inclusive a recuperação de senha. Nenhuma classe Java mudou nesta etapa: o `mvn verify` da Etapa 11 continua valendo (422 unitários, 89 de integração, cobertura unitária 100%).

Etapa 13 — Infraestrutura em módulos substituíveis

O núcleo (`domain`, `application`, `adapter`) tinha as fronteiras verificadas no build desde a Etapa 1. A `infrastructure`, não: era um único anel em que tudo podia importar tudo, organizado por nomes genéricos (`config`, `security`, `persistence`) que não diziam **qual porta** cada pacote atende nem **qual tecnologia** o implementa. Martin trata frameworks, web e banco como *detalhes* — plugins das regras de negócio (*Clean Architecture*, caps. 17 e 30–32) —, e um plugin só merece o nome se puder ser trocado sozinho. O mapa de dependências mostrou que nenhum podia:

Acoplamento encontrado	Efeito ao trocar a tecnologia
A auditoria da persistência (<code>AuthenticatedAuditorAware</code>) lia o <code>SecurityContextHolder</code> do Spring Security	trocar a autenticação quebrava a persistência
<code>persistence.address</code> ↔ <code>persistence.user</code> se importavam	ciclo entre pacotes — nenhuma regra o pegava
O filtro HTTP dependia do <code>JwtTokenIssuer</code> concreto	trocar o formato do token mexia na cadeia HTTP
<code>security/</code> misturava Spring Security HTTP, jjwt, BCrypt e SecureRandom	quatro motivos de mudança num pacote só
<code>config/</code> importava propriedades de JWT e de e-mail, filtro, <i>entry point</i> e controllers	todo módulo novo editava o mesmo pacote
A validade do token de redefinição morava em <code>MailProperties</code>	política de autenticação dentro do módulo de SMTP

Estrutura

```

infrastructure/
  main/          composição: CompositionConfig, PasswordResetProperties
  web/           entrega HTTP (Spring MVC)
    api/user/, api/auth/  error/    doc/    validation/
    security/    SecurityConfig, BearerTokenAuthenticationFilter, IAccessTokenReader, AuthenticatedActor, ...
  persistence/jpa/ PersistenceConfig, TransactionalUnitOfWork
    audit/       AuditableJpaEntity, AuthenticatedAuditorAware, ClockDateTimeProvider
    user/        *JpaEntity (inclui AddressJpaEntity), SpringData*Repository, *DataSourceJpa
  token/jwt/     JwtTokenIssuer, JwtProperties, JwtConfig
  crypto/       BCryptPasswordAdapter, SecureRandomTokenGenerator
  mail/smtp/     SmtplibMailGateway, MailProperties, MailConfig

```

O pacote diz o **papel** e o subpacote a **tecnologia** (*screaming architecture*, cap. 21). Trocar JPA por JDBC é criar `persistence/jdbc` ao lado; trocar o JWT por um token opaco é criar `token/<outro>`. Cada módulo tem um `package-info.java` dizendo qual porta implementa, qual tecnologia usa e o que é preciso para substituí-lo.

O que foi entregue nesta etapa

Decisão	Conceito que a sustenta
Só main liga os módulos. <code>CompositionConfig</code> monta os controllers de adaptação, fornece o <code>Clock</code> e liga um módulo ao outro; nenhum módulo importa um irmão.	O componente Main é o mais sujo do sistema e o único que conhece todos os outros (cap. 26). Os demais continuam plugáveis porque só ele os conhece.
A web não conhece JWT. O filtro lê o <code>Bearer</code> pela porta <code>IAccessTokenReader</code> , declarada em <code>web/security</code> , e o <code>JwtTokenIssuer</code> a implementa junto com <code>ITokenIssuer</code> . O filtro e o <i>entry point</i> perderam o <code>Jwt</code> do nome (<code>BearerTokenAuthenticationFilter</code> , <code>ProblemDetailAuthenticationEntryPoint</code>).	DIP: a interface pertence a quem a consome (<i>Agile PPP</i>). CCP: emitir e ler o mesmo formato mudam juntos, então ficam no mesmo módulo (cap. 13). Nomes revelam intenção (<i>Clean Code</i> cap. 2): uma classe que não sabe o que é JWT não pode se chamar <code>Jwt...</code> . O teste do filtro passou a usar um leitor falso — nenhum JWT em cena.
A persistência não conhece segurança. <code>web/security/AuthenticatedActor</code> sabe quem está autenticado; <code>AuthenticatedAuditorAware</code> recebe um <code>Supplier<Optional<String>></code> ; o <code>main</code> liga um ao outro. O comportamento é o mesmo (<code>system</code> quando não há autor).	Uma fronteira entre dois detalhes é desenhada como qualquer outra: por uma abstração, e cruzada só onde tudo se encontra — no Main.
O ciclo sumiu. <code>AddressJpaEntity</code> foi para <code>persistence/jpa/user</code> : é mapeamento do agregado usuário (a chave estrangeira é dele).	ADP (cap. 14): pacotes num ciclo formam um bloco só, que ninguém troca, testa ou entende separadamente.
Cada módulo traz a própria configuração (<code>JwtConfig</code> , <code>MailConfig</code> , <code>PersistenceConfig</code> , <code>SecurityConfig</code> , <code>OpenApiConfig</code>); <code>config/</code> deixou de existir.	CCP e OCP no nível de componente: apagar um módulo não deixa referência em outro lugar, e acrescentar um não edita um pacote central.
A validade do token é política de autenticação. <code>main/PasswordResetProperties</code> (<code>PASSWORD_RESET_TOKEN_EXPIRATION_MINUTES</code>) substitui o campo em <code>MailProperties</code> , e o caso de uso passa a validade ao e-mail: <code>IMailGateway.sendPasswordReset(to, token, validity)</code> .	Uma fonte de verdade. O caso de uso é quem calcula o vencimento; se o texto do e-mail tivesse configuração própria, o token poderia valer 30 minutos e a mensagem dizer 60.
Substituibilidade verificada no build: <code>InfrastructureModulesTest</code> , 14 regras <code>ArchUnit</code> .	Uma estrutura de pastas é só intenção; o que a sustenta é a regra que quebra o build (o mesmo raciocínio da regra de dependência desde a Etapa 1).

Um desvio consciente do escopo. A etapa era para ficar só na infraestrutura, mas a validade do token não tinha como sair do módulo de e-mail sem uma de três coisas: o e-mail depender do `main` (um plugin conhecendo a composição), duas propriedades que precisariam concordar, ou a porta `IMailGateway` passar a receber a validade. Foi a terceira — a única que mantém uma fonte de verdade —, com um parâmetro `Duration` (JDK) na porta e a chamada correspondente no `ForgotPasswordUseCase`.

Regras novas (InfrastructureModulesTest)

Regra	Protege
nenhum ciclo entre pacotes, no projeto inteiro	ADP
<code>persistence</code> , <code>crypto</code> e <code>mail</code> não dependem de nenhum outro módulo	cada um trocável sozinho
<code>token</code> só conhece, de <code>web</code> , <code>IAccessTokenReader</code> e <code>AuthenticatedUser</code> — a porta que implementa	trocar o formato do token não toca a web
<code>web</code> não depende de <code>main</code> , <code>persistence</code> , <code>token</code> , <code>crypto</code> nem <code>mail</code>	a entrega HTTP fala por portas
JPA, Hibernate, Spring Data e transação só em <code>persistence</code> (e em <code>main</code> , para ligar o <code>AuditorAware</code>)	o banco é um detalhe
<code>jjwt</code> só em <code>token.jwt</code> ; Spring Mail só em <code>mail.smtp</code>	cada biblioteca no seu módulo
Spring Security só em <code>web</code> e, dele, só <code>spring-security-crypto</code> em <code>crypto</code>	autenticação HTTP não vaza
Spring MVC, HATEOAS, Servlet, Bean Validation e springdoc só em <code>web</code>	a web é um detalhe
classe <code>*Config</code> é <code>@Configuration</code> e toda <code>@Configuration</code> termina em <code>Config</code>	sustenta a exclusão <code>**/infrastructure/**/*Config.class</code> do JaCoCo sem esconder lógica

As regras foram conferidas ao contrário: sete classes temporárias, cada uma violando uma delas (ciclo `audit` ↔ `user` , persistência conhecendo a web, token conhecendo o filtro, web conhecendo o JWT, e-mail conhecendo o `main` , jjwt fora do módulo, `@Configuration` sem o sufixo), fizeram falhar exatamente as sete regras visadas.

De → para

Antes (etapas 5 a 12)	Agora
<code>infrastructure/config/CompositionConfig</code>	<code>infrastructure/main/CompositionConfig</code>
<code>infrastructure/config/{SecurityConfig, OpenApiConfig, PersistenceConfig}</code>	<code>web/security</code> , <code>web/doc</code> , <code>persistence/jpa</code>
<code>infrastructure/security/{JwtTokenIssuer, JwtProperties}</code>	<code>infrastructure/token/jwt</code>
<code>infrastructure/security/{BCryptPasswordAdapter, SecureRandomTokenGenerator}</code>	<code>infrastructure/crypto</code>
<code>infrastructure/security/JwtAuthenticationFilter</code>	<code>web/security/BearerTokenAuthenticationFilter</code>
<code>infrastructure/security/JwtAuthenticationEntryPoint</code>	<code>web/security/ProblemDetailAuthenticationEntryPoint</code>
<code>infrastructure/security/{AuthenticatedUser, UserSecurity}</code>	<code>infrastructure/web/security</code>
<code>infrastructure/persistence/{user, address}</code>	<code>infrastructure/persistence/jpa/user</code>
<code>infrastructure/persistence/{AuditableJpaEntity, AuthenticatedAuditorAware, ClockDateTimeProvider}</code>	<code>infrastructure/persistence/jpa/audit</code>
<code>infrastructure/persistence/TransactionalUnitOfWork</code>	<code>infrastructure/persistence/jpa</code>
<code>infrastructure/mail/*</code>	<code>infrastructure/mail/smtp</code>
<code>infrastructure/web/{user, auth}</code>	<code>infrastructure/web/api/{user, auth}</code>
<code>MAIL_RESET_TOKEN_EXPIRATION_MINUTES</code>	<code>PASSWORD_RESET_TOKEN_EXPIRATION_MINUTES</code>

Verificação

Verificação	Resultado
<code>mvn clean verify</code>	441 testes unitários (427 + 14 regras novas) e 89 de integração — BUILD SUCCESS; cobertura unitária 1022/1022 linhas, 226/226 ramos, 431/431 métodos
Movimentação	62 classes movidas com <code>git mv</code> (histórico preservado); nenhum teste de integração precisou mudar além do pacote
Pilha do Compose com <code>PASSWORD_RESET_TOKEN_EXPIRATION_MINUTES=45</code>	o token grava vencimento em 45 minutos e o e-mail diz " <i>Ele vale por 45 minutos</i> " — a validade viaja da configuração ao caso de uso e dele ao texto, por uma fonte só
Coleção Postman (<code>npx newman@6</code>)	52 requests, 108 asserções, nenhuma falha; <code>cliente.demo</code> intacto

Nenhum comportamento HTTP mudou, e por isso os prints da Etapa 12 continuam valendo.

Decisões Técnicas (registro consolidado)

- **Infraestrutura em módulos substituíveis:** o pacote diz o papel, o subpacote a tecnologia; nenhum módulo conhece outro, só o Main os liga; sem ciclos; cada biblioteca confinada ao seu módulo — tudo verificado por ArchUnit. Etapa 13.
- **Testes em dois níveis obrigatórios:** unitários com **100% de cobertura** de linhas e ramos (JaCoCo bloqueia o build abaixo disso) e de integração com contexto Spring completo, PostgreSQL real via Testcontainers e requisições HTTP de ponta a ponta, cobrindo todos os endpoints e fluxos. Etapa 11.
- **Clean Architecture:** quatro camadas concêntricas (Entidades, Casos de Uso, Adaptadores de Interface, Frameworks & Drivers) com dependência sempre para dentro, verificada por ArchUnit. Detalhado na Visão Geral e na Etapa 11.
- **Entidades validam os próprios invariantes:** fábrica `create(...)` e setters validados; nenhuma instância inválida existe no sistema. Etapa 2.
- **Um caso de uso por ação,** com `create(...)` / `run(...)`, dependendo apenas de interfaces de gateway. Regras de negócio na entidade; regras de aplicação no caso de uso. Etapa 3.
- **Controller como orquestrador:** recebe a origem de dados por interface, instancia gateway e caso de uso, delega ao presenter. Etapa 4.
- **JPA confinado à infraestrutura,** com entidades JPA separadas das de domínio; relacionamentos, cascade e auditoria declarativos. Etapa 5.
- **Identificadores UUID gerados pelo banco,** para impedir enumeração de recursos. Etapa 5.
- **Schema versionado com Flyway** (`ddl-auto: validate`). Etapa 6.
- **Autenticação stateless com JWT** e senha em BCrypt; **autorização por posse** para evitar IDOR; autocadastro não concede `ROLE_ADMIN`. Etapa 7.
- **Padrão de erros ProblemDetail (RFC 7807).** Etapa 8.
- **Versionamento de API por path** (`/api/v1/...`). Etapa 7.
- **HATEOAS** nas respostas REST; **Actuator** para monitoramento. Etapa 7.
- **Sem Lombok nem geração de código no núcleo.** Etapa 1.
- **Paginação expressa em tipos próprios** (`PageRequest`, `PageResult`) no núcleo; `Pageable` / `Page` do Spring só na infraestrutura. Etapa 3.

Referências Bibliográficas

Arquitetura e código

- MARTIN, R. *Clean Architecture: A Craftsman's Guide to Software Structure and Design*. Prentice Hall, 2017. Camadas concêntricas, regra de dependência, casos de uso, entidades e a tese de que banco de dados e frameworks são detalhes.

- MARTIN, R. *The Clean Architecture*. The Clean Code Blog, 2012. Artigo original com o diagrama dos anéis (Entities, Use Cases, Interface Adapters, Frameworks & Drivers).
- MARTIN, R. *Clean Code: A Handbook of Agile Software Craftsmanship*. Prentice Hall, 2009. Nomes, funções curtas, tratamento de erros por exceções e testes limpos.
- MARTIN, R. *Agile Principles, Patterns, and Practices in C#*. Pearson, 2006. Princípios SOLID, em especial a inversão de dependência usada nos gateways.
- MARTIN, R. *The Clean Coder: A Code of Conduct for Professional Programmers*. Prentice Hall, 2011. Responsabilidade profissional sobre a qualidade do que se entrega.

Casos de uso e padrões

- COCKBURN, A. *Writing Effective Use Cases*. Addison-Wesley, 2000.
- FREEMAN, E.; ROBSON, E. *Use a Cabeça! Padrões de Projeto (Head First Design Patterns)*.

Banco de dados

- DATE, C. J. *Introdução a Sistemas de Bancos de Dados*. Modelo relacional, formas normais e integridade referencial.
- MACHADO, Felipe Nery Rodrigues. *Banco de Dados: Projeto e Implementação*. Projeto de banco em três níveis e modelo entidade-relacionamento.